

杭州电子科技大学

网络空间安全技术课程设计

实 验 报 告

学 院

网络空间安全学院

专 业

网络空间安全

班 级

Xx

学 号

xx

学生姓名

xx

教师姓名

王秋华

完成日期

2025.12.9

成 绩

实验三 以太网安全防御实验

一、实验目的

访问控制列表实验

- (1) 验证交换机端口静态配置访问控制列表的过程
- (2) 验证访问控制列表控制终端接入的过程
- (3) 验证关闭端口的重新开启过程

安全端口实验

- (1) 验证交换机端口安全功能配置过程
- (2) 验证访问控制列表自动添加 MAC 地址的过程
- (3) 验证对违规接入终端采取的各种动作的含义
- (4) 验证安全端口方式下的终端接入控制过程

MAC 地址欺骗攻击实验

- (1) 验证交换机建立 MAC 表 (转发表) 过程
- (2) 验证交换机转发 MAC 帧机制
- (3) 验证 MAC 地址欺骗攻击原理
- (4) 掌握 MAC 地址欺骗攻击过程

防 DHCP 欺骗攻击实验

- (1) 验证 DHCP 服务器配置过程
- (2) 验证 DNS 服务器配置过程
- (3) 验证终端用完全合格的域名访问 Web 服务器的过程
- (4) 验证 DHCP 欺骗攻击过程
- (5) 验证钓鱼网站实施过程
- (6) 验证交换机防 DHCP 欺骗攻击功能的配置过程

二、实验原理

1.利用集线器的什么原理可以实施嗅探攻击？

集线器基于共享介质的广播转发原理，会将所有设备的通信数据复制到所有端口，攻击者接入后只需将网卡切换为混杂模式，即可捕获经过该集线器的所有网络数据，从而实施嗅探攻击。

2.通过交换机可以有哪些方式实施窃听攻击？

攻击者可通过 ARP 欺骗（伪造 ARP 响应篡改交换机 MAC 地址表，将目标流量引向

自身)、MAC 泛洪(发送大量伪造 MAC 地址使交换机地址表溢出并广播数据帧)、端口镜像(非法配置交换机将目标端口流量镜像至自身端口)、VLAN 跳跃(利用交换机配置缺陷跨 VLAN 访问并窃听流量)等方式,绕开交换机定向转发机制实施窃听攻击。

3.访问控制列表实验原理:

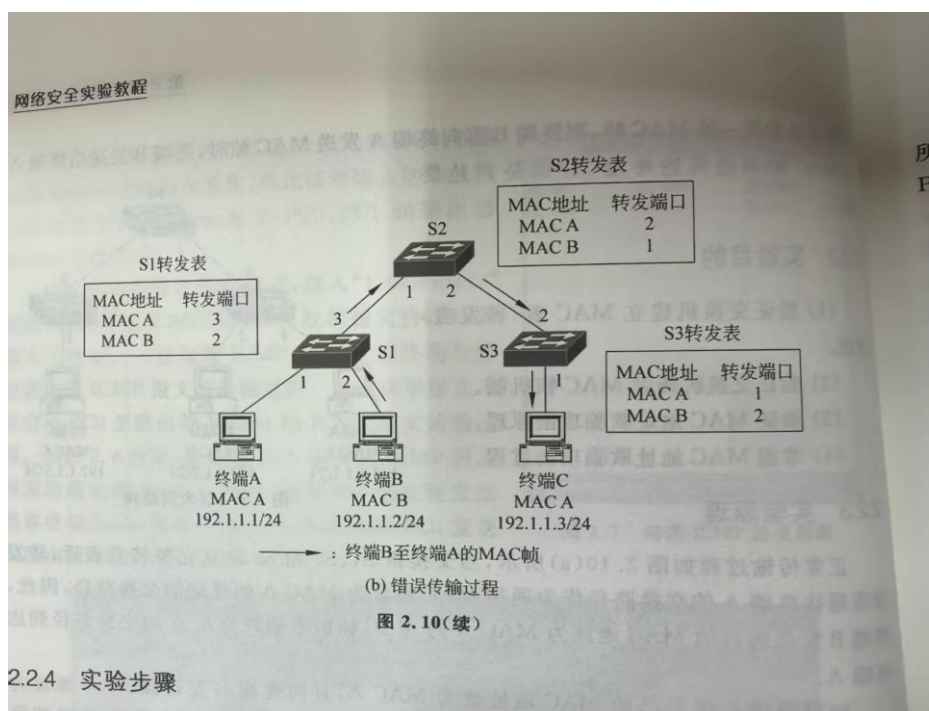
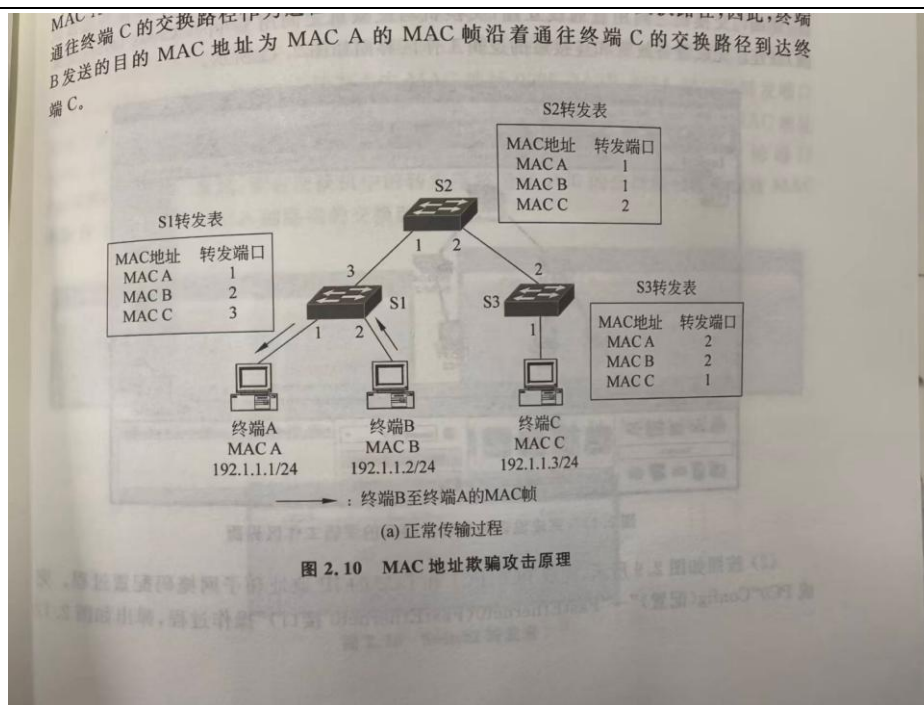
由于交换机端口 1 的访问控制列表中静态配置了终端 A 的 MAC 地址,因此当终端 A 接入交换机端口 1 且向交换机端口 1 发送 MAC 帧时,MAC 帧的源 MAC 地址与访问控制列表中的 MAC 地址相同,交换机继续转发该 MAC 帧。当终端 B 接入交换机端口 1 且向交换机端口 1 发送 MAC 帧时,由于 MAC 帧的源 MAC 地址与访问控制列表中的 MAC 地址不同,因此交换机丢弃该 MAC 帧,并关闭交换机端口 1。需要通过特殊的命令序列才能重新开启交换机端口 1。

4.安全端口实验原理:

由于交换机端口 1 设置为安全端口,且将访问控制列表中的最大 MAC 地址数设置为 2,因此,当分别将终端 A 和终端 B 接入交换机端口 1,且向交换机端口 1 发送 MAC 帧后,访问控制列表中已经添加终端 A 和终端 B 的 MAC 地址。当终端 C 接入交换机端口 1 且向交换机端口 1 发送 MAC 帧时,由于 MAC 帧的源 MAC 地址不属于访问控制列表中的 MAC 地址,且访问控制列表中的 MAC 地址数已经达到最大地址数 2,因此,交换机丢弃该 MAC 帧。

5.MAC 地址欺骗攻击原理:

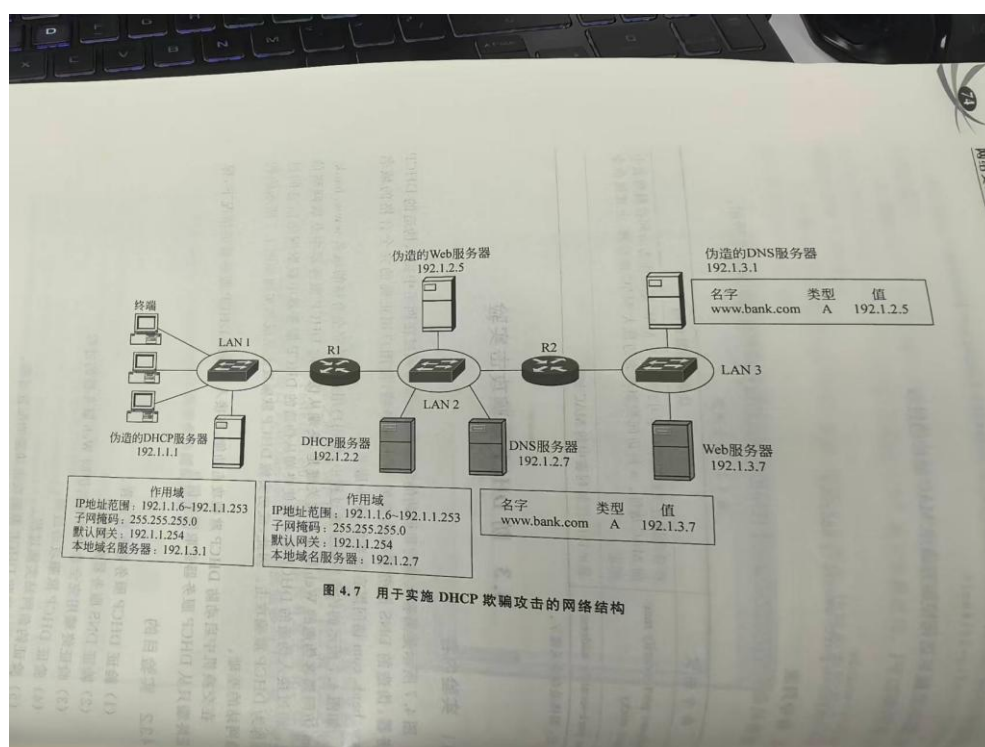
正常传输过程如图 2.10(a) 所示,当交换机 S1、S2 和 S3 建立完整转发表后,转发项将通往终端 A 的交换路径作为通往 MAC 地址为 MAC A 的终端的交换路径,因此,终端 B 发送的目的 MAC 地址为 MAC A 的 MAC 帧沿着通往终端 A 的交换路径到达终端 A。如果终端 C 将自己的 MAC 地址改为 MAC A,且向终端 B 发送源 MAC 地址为 MAC A 的 MAC 帧,交换机 S1、S2 和 S3 的转发表改为如图 2.10(b) 所示,转发项将通往终端 C 的交换路径作为通往 MAC 地址为 MAC A 的终端的交换路径,因此,终端 B 发送的目的 MAC 地址为 MAC A 的 MAC 帧沿着通往终端 C 的交换路径到达终端 C。



6.防 DHCP 欺骗攻击实验原理：

终端通过 DHCP 自动获取的网络信息中包含本地域名服务器地址，对于如图 4.7 所示的网络应用系统，DHCP 服务器中给出的本地域名服务器地址是 192.1.2.7，地址为 192.1.2.7 的域名服务器中与完全合格的域名 www.bank.com 绑定的 Web 服务器地址是 192.1.3.7。因此，终端可以用完全合格的域名 www.bank.com 访问 Web 服务器。一旦终端连接的网络中接入伪造的 DHCP 服务器，终端很可能从伪造的 DHCP 服务器获

取网络信息，得到伪造的域名服务器的 IP 地址 192.1.3.1，伪造的域名服务器中将完全合格的域名 `www.bank.com` 与伪造的 Web 服务器的 IP 地址 192.1.2.5 绑定在一起，导致终端用完全合格的域名 `www.bank.com` 访问伪造的 Web 服务器。如果交换机启动防 DHCP 欺骗攻击的功能，只有连接在信任端口的 DHCP 服务器才能为终端提供自动配置网络信息的服务。因此，对于如图 4.7 所示的实施 DHCP 欺骗攻击的网络应用系统，连接终端的以太网中，如果只将连接路由器 R1 的交换机端口设置为信任端口，将其他交换机端口设置为非信任端口，则终端只能接收由路由器 R1 转发的 DHCP 消息，使终端只能获取 DHCP 服务器提供的网络信息。



三、 实验环境/实验拓扑图

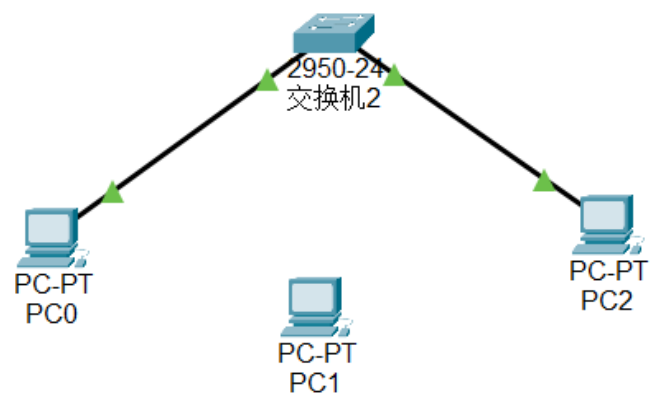


图 1 访问控制列表实验拓扑图

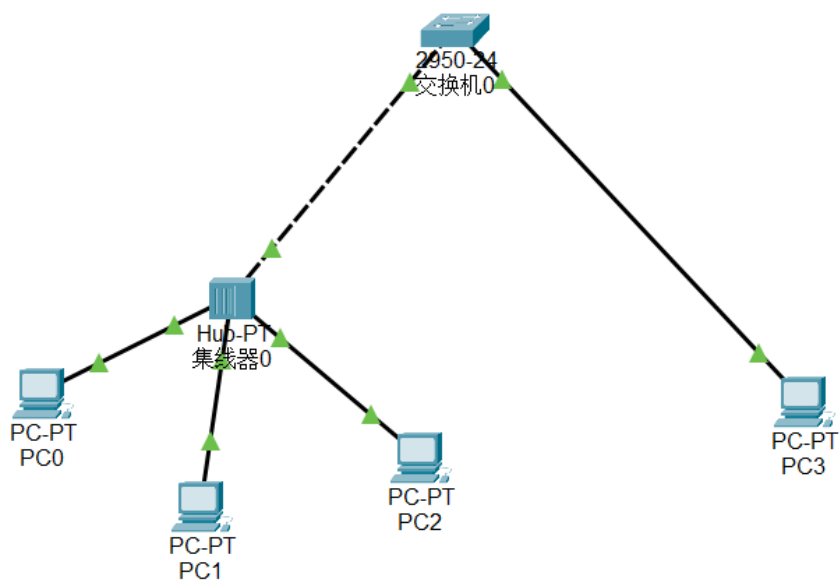


图 2 安全端口实验拓扑图

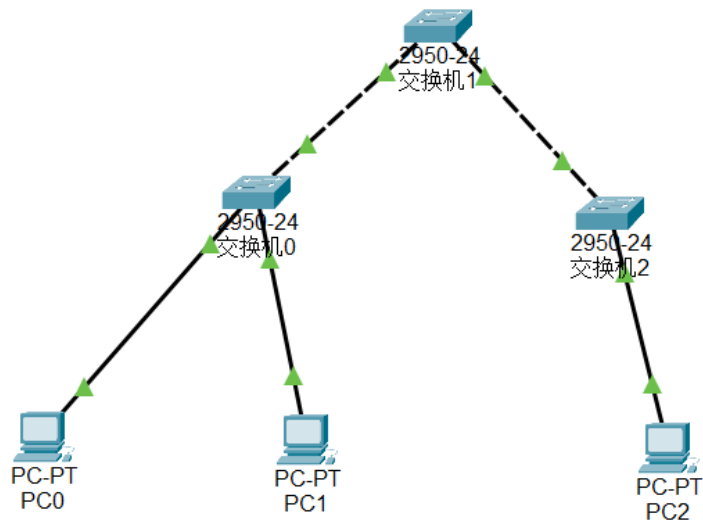


图 3 MAC 地址欺骗攻击实验拓扑图

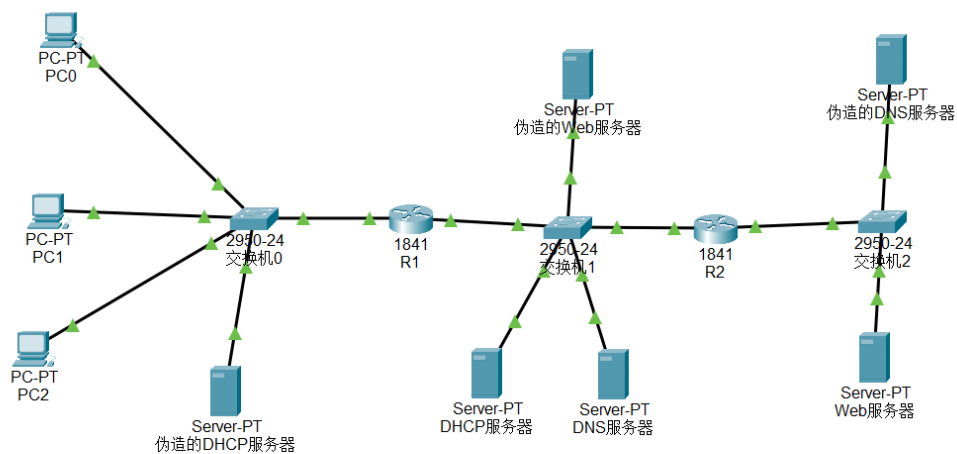


图 4 防 DHCP 欺骗攻击实验拓扑图

四、 主要操作步骤及实验结果记录

访问控制列表实验：

(1) 完成 3 个终端 PC0、PC1 和 PC2 的网络信息配置过程。具体配置信息如下：

PC0:IP-192.1.1.10 MAC- 00D0.BAB7.B7D9

PC1:IP-192.1.1.20 MAC- 0001.6403.B2D7

PC2:IP-192.1.1.30 MAC- 0001.43A5.2D5E

(2) 将 PC2 连接到交换机端口 FastEthernet0/2。在 CLI（命令行接口）配置方式下，完成交换机端口 FastEthernet0/1 安全功能配置过程，在访问控制列表中静态配置 PC0 的 MAC 地址，如图 5 所示。

```

Switch(config)#interface FastEthernet0/7
Switch(config-if)#e
Switch(config-if)#exit
Switch(config)#interface FastEthernet0/1
Switch(config-if)#switchport mode access
Switch(config-if)#switchport port-security
Switch(config-if)#switchport port-security maximum 1
Switch(config-if)#switchport port-security mac-address 00D0.BAB7.B7D9
Switch(config-if)#switchport port-security violation shutdown
Switch(config-if)#exit
Switch(config)#
%LINK-3-UPDOWN: Interface FastEthernet0/1, changed state to down

%LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/1, changed state to down

%LINK-5-CHANGED: Interface FastEthernet0/1, changed state to up

```

图5 交换机命令配置

• **switchport mode access:** 接口配置模式下的命令，用于将交换机端口 FastEthernet0/1 指定为接入端口。交换机端口模式有 access（接入端口）、trunk（共享端口）和 dynamic（动态端口）三种，仅接入端口和共享端口允许启动安全功能。

• **switchport port-security:** 接口配置模式下的命令，用于启动交换机端口 FastEthernet0/1 的安全功能。执行该命令前，交换机端口 FastEthernet0/1 需处于接入端口模式或共享端口模式。

• **switchport port-security maximum 1:** 接口配置模式下的命令，用于指定交换机端口 FastEthernet0/1 对应的访问控制列表中的最大 MAC 地址数，此处最大 MAC 地址数为 1。

• **switchport port-security mac-address 00D0.BAB7.B7D9:** 接口配置模式下的命令，用于静态配置访问控制列表中的 MAC 地址，00D0.BAB7.B7D9 是十六进制表示的 48 位 MAC 地址。

• **switchport port-security violation shutdown:** 接口配置模式下的命令，用于指定交换机端口接收到源 MAC 地址不属于访问控制列表中 MAC 地址的 MAC 帧时采取的动作，shutdown 表示采取关闭端口的动作，重新开启端口需执行特殊命令序列。

将 PC0 连接到交换机端口 FastEthernet0/1，完成设备放置和连接后的逻辑工作区界面如图 6 所示。

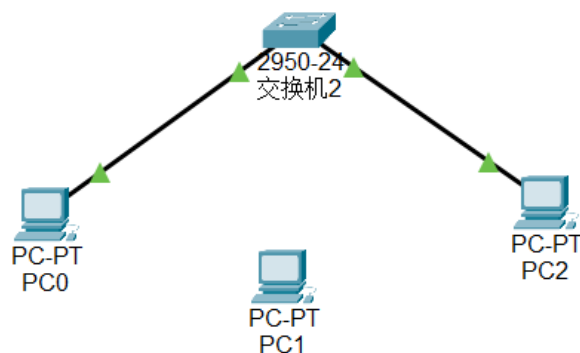


图6 实验拓扑图

(3) 启动 PC0 与 PC2 之间的 ICMP 报文交换过程。PC0 和 PC2 之间能够成功交换 ICMP 报文。


```

C:\>
C:\>ping 192.1.1.30

Pinging 192.1.1.30 with 32 bytes of data:

Reply from 192.1.1.30: bytes=32 time<1ms TTL=128
Reply from 192.1.1.30: bytes=32 time<1ms TTL=128
Reply from 192.1.1.30: bytes=32 time=4ms TTL=128
Reply from 192.1.1.30: bytes=32 time<1ms TTL=128

Ping statistics for 192.1.1.30:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 4ms, Average = 1ms

```

图 7 PC0 与 PC2 连通测试

(4) 删除 PC0 与交换机端口 FastEthernet0/1 之间的连接，将 PC1 连接到交换机端口 FastEthernet0/1。完成设备连接后的逻辑工作区界面如图 8 所示。

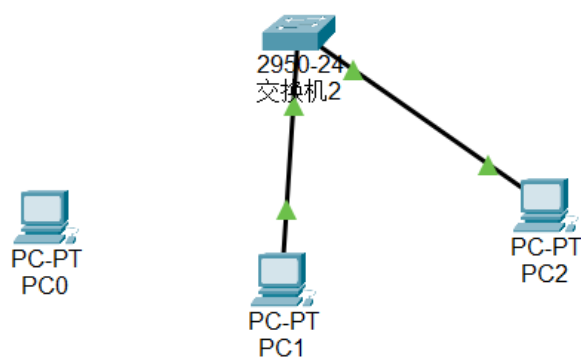


图 8 实验拓扑图

(5) 启动 PC1 与 PC2 之间的 ICMP 报文交换过程，导致交换机端口 FastEthernet/1 关闭。如图 9 所示。

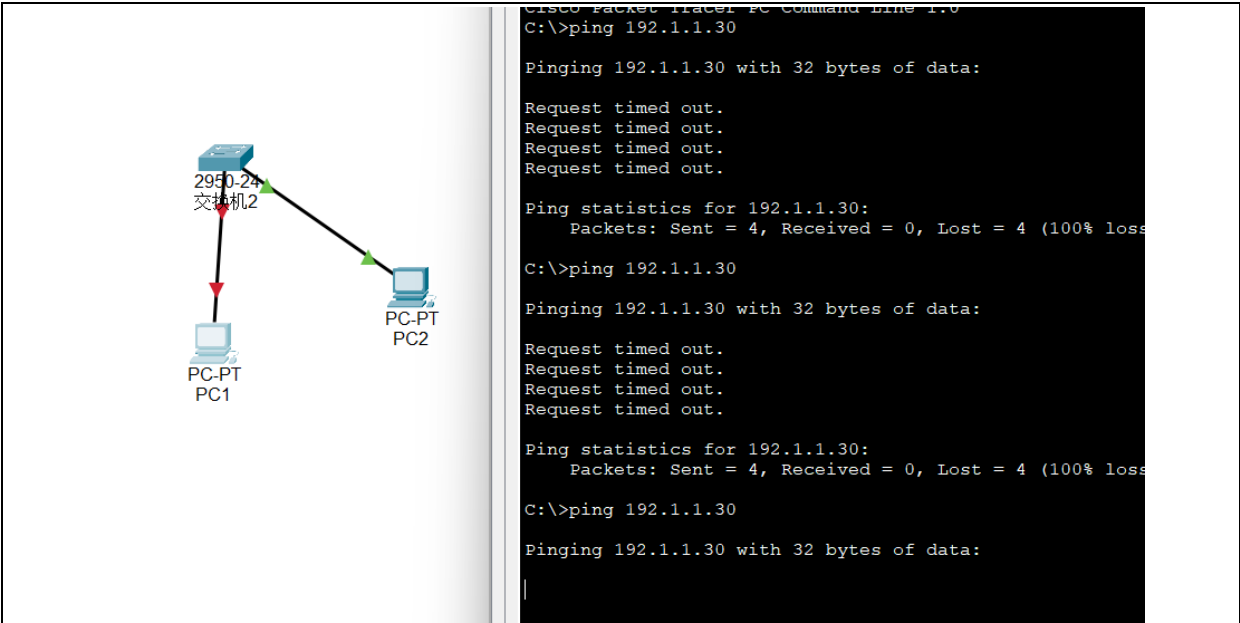


图 9 PC1 与 PC2 连通测试

(6)通过在交换机端口 FastEthernet0/1 对应的接口配置模式下执行命令 shutdown 和 no shutdown 重新开启交换机端口 FastEthernet0/1, 但只有当 PC0 接入该交换机端口时, 才能正常传输 MAC 帧。重新打开端口后再使用 PC0 与 PC2 连通测试, 发现可以成功连通。

```
Switch(config)#interface FastEthernet 0/1
Switch(config-if)#shutdown

%LINK-5-CHANGED: Interface FastEthernet0/1, changed state to administratively down
Switch(config-if)#no shutdown

Switch(config-if)#
%LINK-5-CHANGED: Interface FastEthernet0/1, changed state to up

%LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/1, changed state to up

Switch(config-if)#exit
Switch(config)#
```

图 10 重新打开端口

本次实验所用主要命令如下：

命令格式	功能和参数说明
switchport mode {access dynamic trunk}	将交换机端口模式指定为以下三种模式之一：access (接入端口)、trunk (共享端口)、根据链路另一端端口模式确定端口模式的 dynamic (动态端口)
switchport port-security	启动交换机端口安全功能
switchport port-security maximum value	设置访问控制列表中最大 MAC 地址数。参数 value 是最大 MAC 地址数
switchport port-security mac-address mac-address	静态配置访问控制列表中的 MAC 地址，MAC 地址数不能超过设置的最大 MAC 地址数。参数 mac-address 是十六进制表示的 48 位 MAC 地址

switchport port-security violation [protect restrict shutdown]	指定交换机接收到源 MAC 地址不属于访问控制列表中的 MAC 地址的 MAC 帧时的动作。protect 只是丢弃该 MAC 帧。restrict 是丢弃该 MAC 帧，计数丢弃的 MAC 帧数量，并在日志中记录该事件。 shutdown 是丢弃该 MAC 帧，计数丢弃的 MAC 帧数量，在日志中记录该事件，并关闭该交换机端口
--	--

表 1 访问控制列表实验重要命令

安全端口实验：

(1) 完成 4 个终端 PC0、PC1、PC2 和 PC3 的网络信息配置过程。具体配置信息如下：

PC0:IP-192.1.1.10 MAC- 0060.4756.50A6

PC1:IP-192.1.1.20 MAC- 0004.9A4B.CD46

PC2:IP-192.1.1.30 MAC- 0006.2AEB.2BCE

PC3:IP-192.1.1.40 MAC- 0001.4290.1D08

(2) 将 PC3 连接到交换机端口 FastEthernet0/2。在 CLI（命令行接口）配置方式下，完成交换机端口 FastEthernet0/1 安全功能配置过程。

```
Switch>enable
Switch#confi
Switch#configure terminal
Enter configuration commands, one per line. End with CNTL/Z.
Switch(config)#inter
Switch(config)#interface
Switch(config)#interface E
Switch(config)#interface Ethernet 0/1
%Invalid interface type and number
Switch(config)#interface
Switch(config)#interface Fast
Switch(config)#interface FastEthernet 0/1
Switch(config-if)#switchport mode access
Switch(config-if)#switchport port-security
Switch(config-if)#switchport port-security maximum 2
Switch(config-if)#switchport port-security mac-address sticky
Switch(config-if)#switchport port-security violation protect
Switch(config-if)#exit
Switch(config)#
```

图 11 交换机端口配置

命令说明：

switchport port-security maximum 2 是接口配置模式下使用的命令，该命令的作用是将访问控制列表的最大 MAC 地址数设置为 2。

switchport port-security mac-address sticky 是接口配置模式下使用的命令，该命令的作用是指定 sticky 作为访问控制列表中 MAC 地址的添加方式，这种添加方式自动将通过端口 FastEthernet0/1 接收到的 MAC 帧的源 MAC 地址添加到访问控制列表中，但添加的 MAC 地址数受设定的最大 MAC 地址数限制，因此，当设定的最大 MAC 地址数为 2 时，自动将最先接收到的 MAC 帧中的两个不同的源 MAC 地址添加到访问控制列表中。

switchport port-security violation protect 是接口配置模式下使用的命令，该命令的作用是指定当交换机端口接收到源 MAC 地址不属于访问控制列表中的 MAC 地址的 MAC 帧，且访问控制列表中的 MAC 地址数已经达到最大 MAC 地址数时所采取的动作。protect 表示采取的动作只是丢弃该 MAC 帧。

(3) 将 PC0 连接到交换机端口 FastEthernet0/1。完成设备放置和连接后的逻辑工作区界面如图 12 所示。

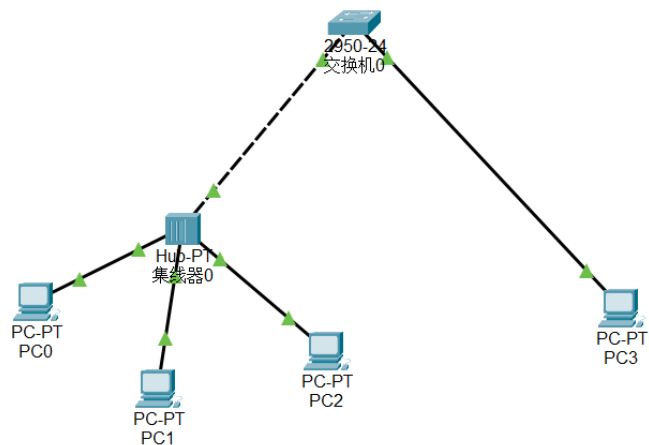


图 12 安全端口实验拓扑图

(4) 启动 PC0 与 PC3 之间的 ICMP 报文交换过程。PC0 和 PC3 之间能够成功交换 ICMP 报文。

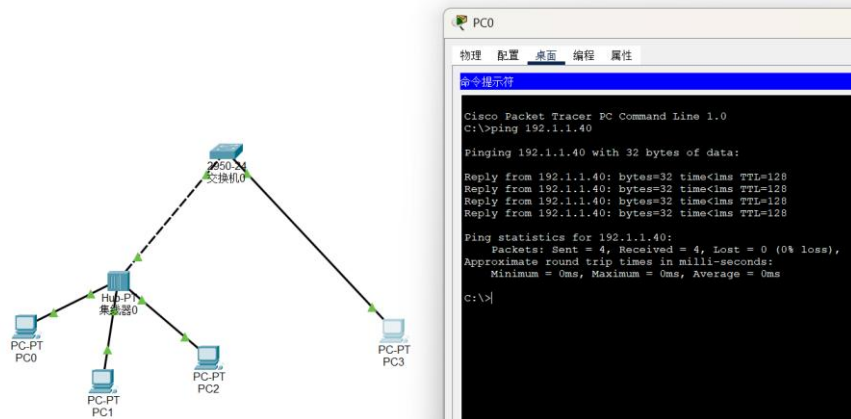


图 13 PC0 连通 PC3 测试

(5) 启动 PC1 与 PC3 之间的 ICMP 报文交换过程。PC1 和 PC3 之间能够成功交换 ICMP 报文。

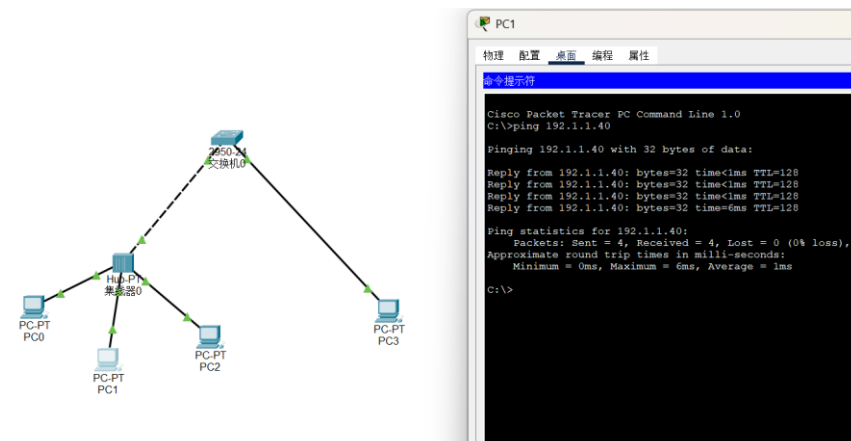


图 14 PC1 连通 PC3 测试

(6) 查看访问控制列表中的 MAC 地址,如图 15 所示,访问控制列表中已经存在 PC0 和 PC1 的 MAC 地址。**show port-security address** 是特权模式下使用的命令,该命令的作用是显示访问控制列表中的 MAC 地址。

```
Switch>enable
Switch#show port-security address
Secure Mac Address Table
-----
Vlan    Mac Address      Type                Ports    Remaining Age
(mins)
-----
1       0004.9A4B.CD46   SecureSticky        Fa0/1    -
1       0060.4756.50A6   SecureSticky        Fa0/1    -
-----
Total Addresses in System (excluding one mac per port)  : 1
Max Addresses limit in System (excluding one mac per port) : 1024
Switch#
```

图 15 查看访问控制列表中 MAC 地址的过程

(6) 启动 PC2 与 PC3 之间的 ICMP 报文交换过程。PC2 和 PC3 之间无法交换 ICMP 报文，如图 16 所示，但交换机端口 FastEthernet0/1 的工作状态没有发生变化。如果再次将 PC0 或 PC1 连接到交换机端口 FastEthernet0/1，则依然能够与 PC3 成功交换 ICMP 报文。

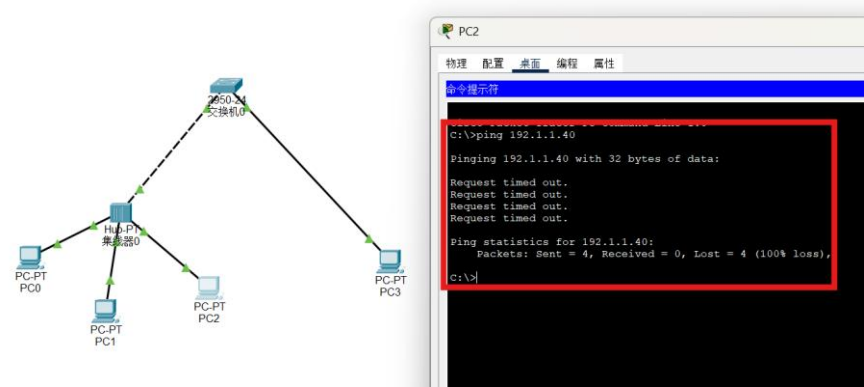


图 16 PC2 连通 PC3 测试

本次实验所用到的主要命令如下表：

命令格式	功能和参数说明
switchport port-security mac-address sticky	将最先通过交换机端口学习到的 n 个 MAC 地址作为访问控制列表中的 MAC 地址。n 是访问控制列表的最大 MAC 地址数，由其他命令指定
show port-security address	显示访问控制列表中的 MAC 地址

表 2 安全端口实验重要命令

MAC 地址欺骗攻击实验：

(1) 启动 Packet Tracer，在逻辑工作区根据网络结构放置和连接设备，终端与交换机之间用直通线连接，交换机与交换机之间用 Copper Cross-Over (交叉线) 连接。完成设备放置和连接后的逻辑工作区界面如图 17 所示。

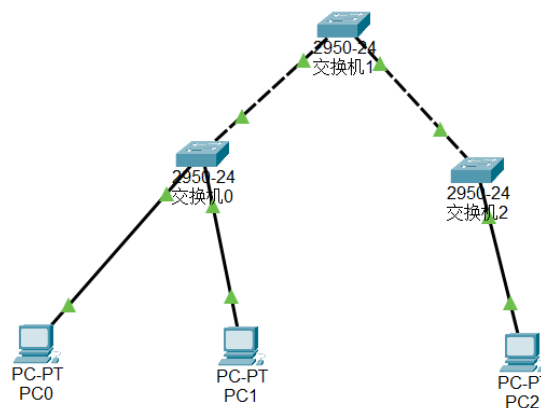


图 17 实验拓扑图

(2)按照课本图 2.9 所示,完成 PC0、PC1 和 PC2 的 IP 地址和子网掩码配置过程。完成 PC0→Config (配置)→FastEthernet0 (FastEthernet0 接口) 操作过程,弹出如图 18 所示的 PC0 FastEthernet0 接口配置界面,其中 MAC Address (MAC 地址栏) 中显示的是 PC0 的 MAC 地址 0006.2A2B.865A。

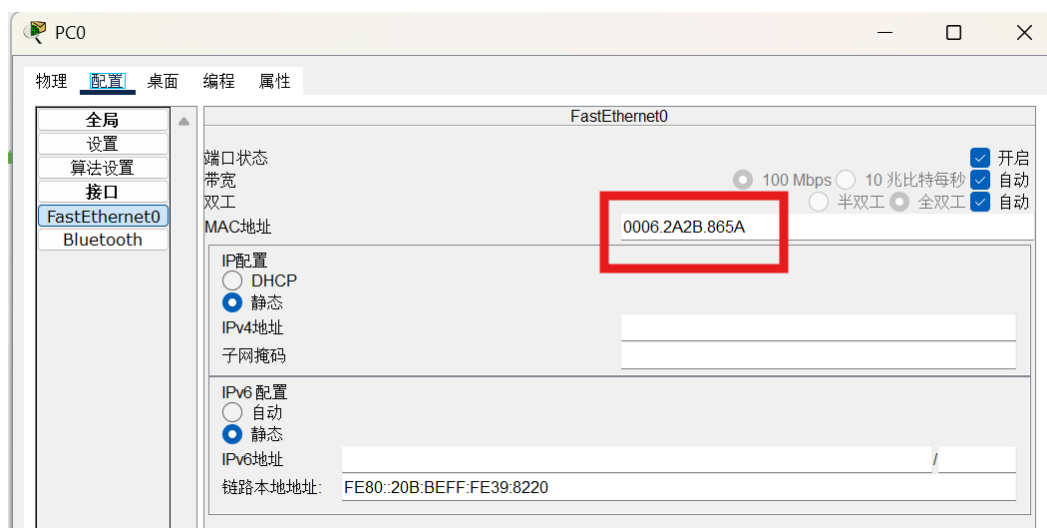


图 18 PC0 MAC 地址配置

最终配置信息如下:

PC0:IP- 192.1.1.1 MAC- 0006.2A2B.865A

PC1:IP- 192.1.1.2 MAC- 0060.2F0A.84B6

PC2:IP- 192.1.1.3 MAC- 00E0.F71D.382B

(3)完成 PC0、PC1 和 PC2 两两之间的 ICMP 报文传输过程,交换机 Switch0、Switch1 和 Switch2 中建立的完整转发表分别如图 19、图 20 和图 21 所示。Switch0 转发表中 MAC 地址 0006.2A2B.865A 对应的转发端口是该交换机连接 PC0 的端口 FastEthernet0/1,Switch1 转发表中 MAC 地址 0006.2A2B.865A 对应的转发端口是该交换机连接交换机 Switch0 的端口 FastEthernet0/1。Switch2 转发表中 MAC 地址 0006.2A2B.865A 对应的转发端口是该交换机连接交换机 Switch1 的端口 FastEthernet0/2。显然,所有交换机中的转发表项将通往 PC0 的交换路径作为通往 MAC 地址为 0006.2A2B.865A 的终端的交换路径。

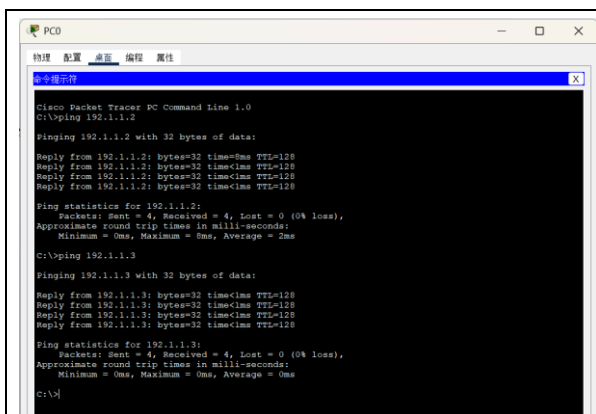


图 19 PC0 连通测试

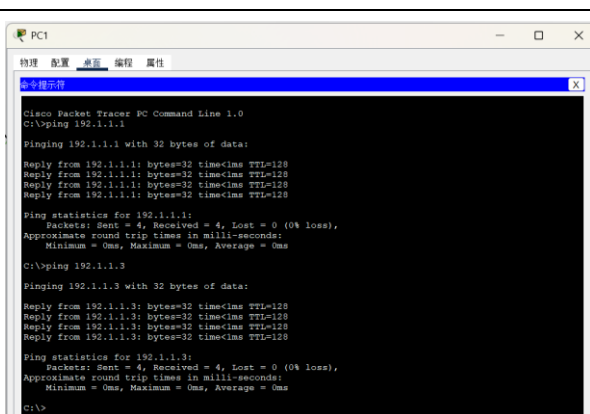


图 20 PC1 连通测试

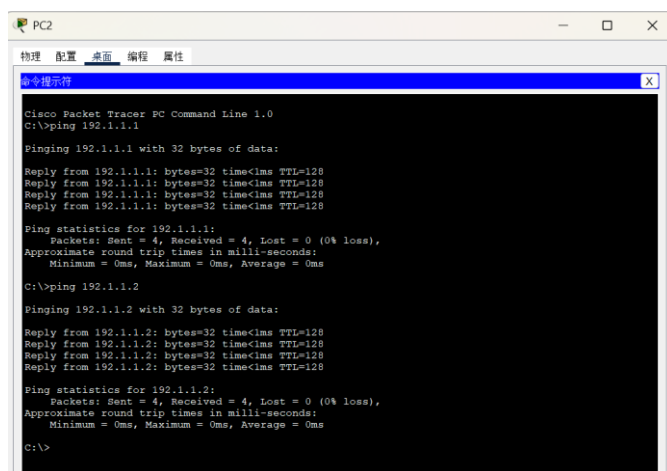


图 21 PC2 连通测试

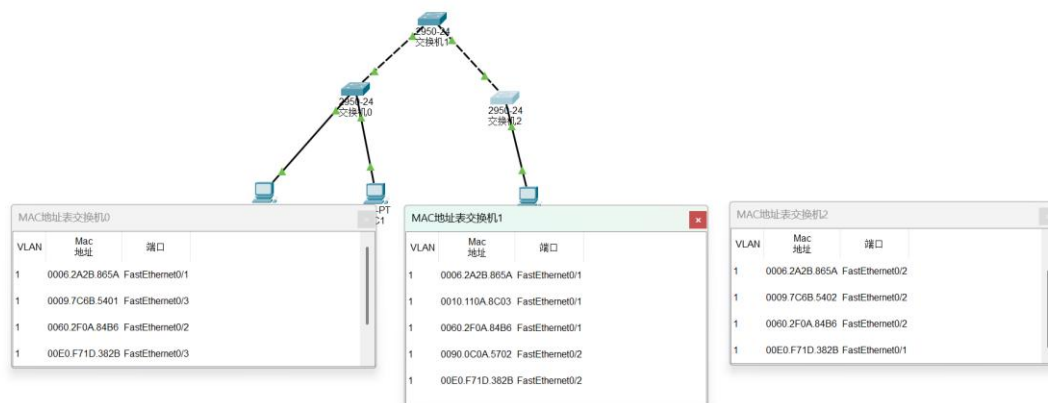


图 22 交换机 MAC 地址表

(4) 切换到模拟操作模式，进入 “Edit Filters” 配置界面，勾选协议 ICMP。通过简单报文工具启动 PC1 至 PC0 的 ICMP 报文传输过程。如图 23 所示，该 ICMP 报文只到达 PC0。

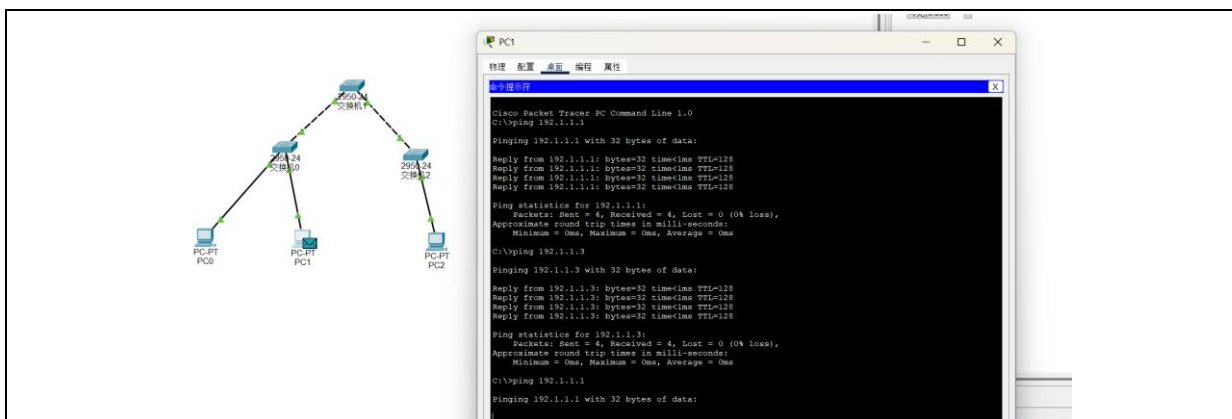


图 23 模拟 PC1->PC0 的 ICMP 报文传输

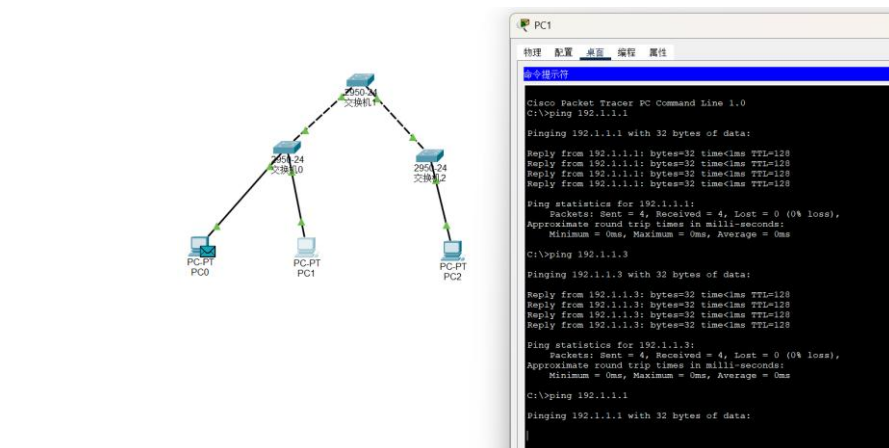


图 24 报文传输完毕

(5) 切换到实时操作模式，完成 PC2→Config (配置)→FastEthernet0 (FastEthernet0 接口) 操作过程，弹出如图 25 所示的 PC2 FastEthernet0 接口配置界面，将 MAC Address (MAC 地址栏) 中的 MAC 地址改为 PC0 的 MAC 地址 0006.2A2B.865A。

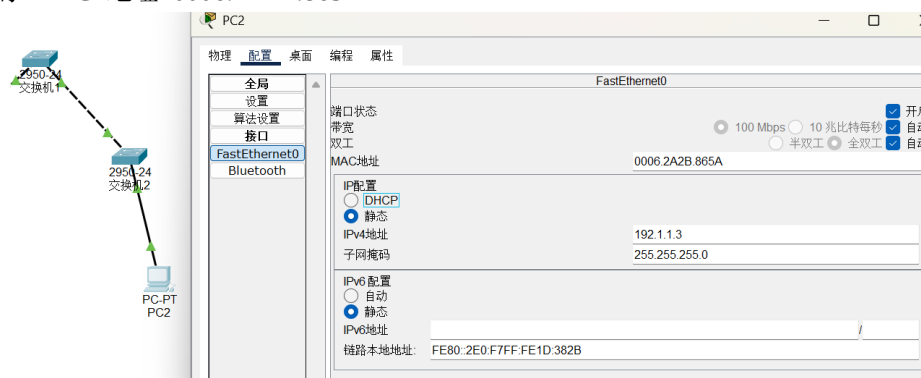


图 25 修改 PC2 MAC 地址

(6) 通过简单报文工具启动 PC2 至 PC1 的 ICMP 报文传输过程，完成 ICMP 报文传输过程后，交换机 Switch0、Switch1 和 Switch2 的转发表分别如图 26 所示。Switch0 转发表中 MAC 地址 0006.2A2B.865A 对应的转发端口改为该交换机连接 Switch1 的端口 FastEthernet0/3。Switch1 转发表中 MAC 地址 0006.2A2B.865A 对应的转发端口改为该交换机连接交换机 Switch2 的端口 FastEthernet0/2。Switch2 转发表中 MAC 地址 0006.2A2B.865A 对应的转发端口改为该交换机连接 PC2 的端口 FastEthernet0/1。显然，所有交换机中的转发表项将通往 PC2 的交换路径作为通往 MAC 地址为 0006.2A2B.865A 的终端的交换路径。

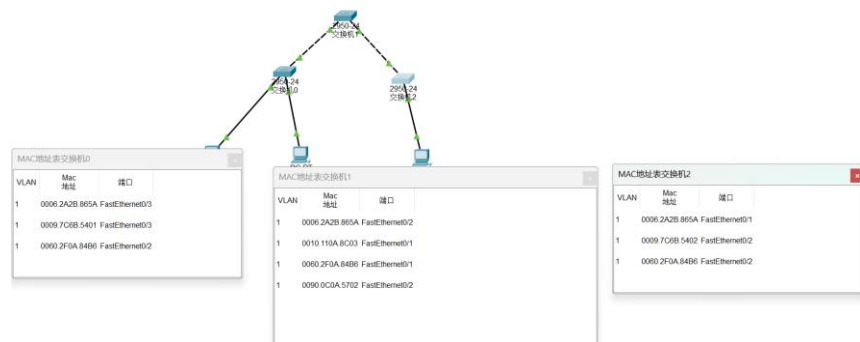


图 26 改变后的交换机 MAC 地址表

(7) 切换到模拟操作模式，通过简单报文工具启动到 PC1 至 PC0 的 ICMP 报文传输过程。如图 28 所示，该 ICMP 报文到达 PC2。

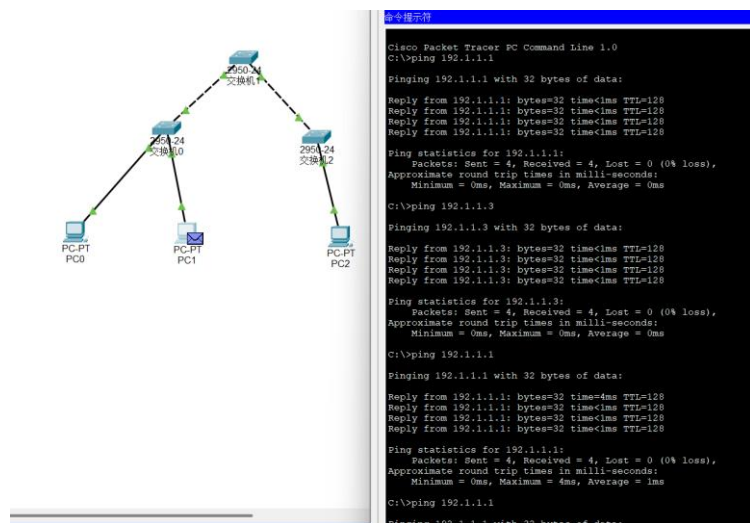


图 27 模拟 PC1->PC0 的 ICMP 报文传输

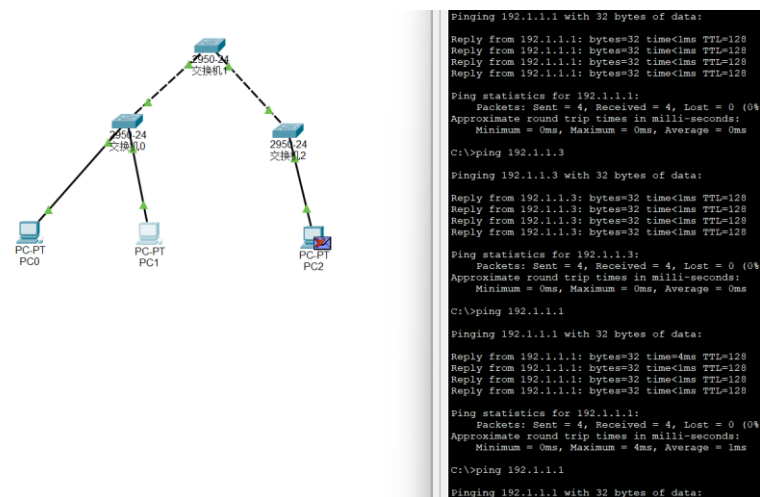


图 28 报文被错误传输给 PC2

防 DHCP 欺骗攻击实验:

(1) 该实验在第 2.5 节中的钓鱼网站实验基础上进行。根据如课本图 4.7 所示的钓鱼网站实施过程完成设备放置和连接，完成设备放置和连接后的逻辑工作区界面如图 29 所示。

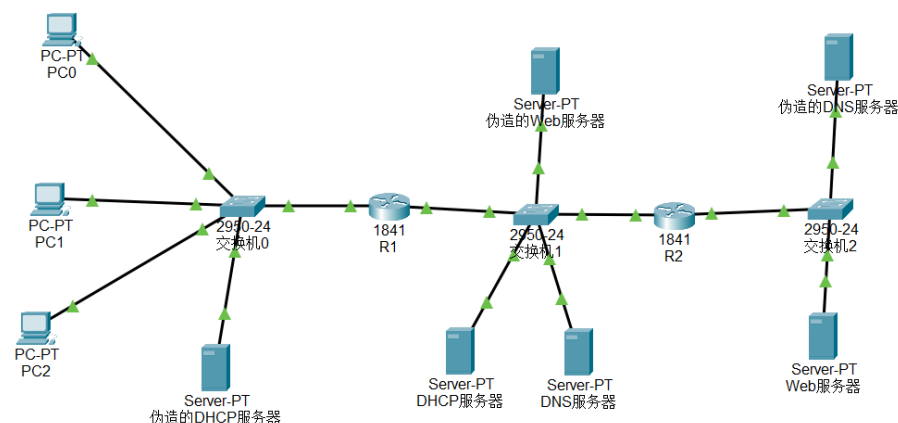


图 29 完成设备放置和连接后的逻辑工作区界面

(2) 在启动交换机 Switch0 防 DHCP 欺骗攻击的功能前，PC0 很可能从伪造的 DHCP 服务器获取网络信息，如图 30 所示，得到的 DNS 服务器地址是伪造的 DNS 服务器的 IP 地址 192.1.3.1，从而使 PC0 用完全合格的域名 www.bank.com 访问伪造的 Web 服务器，如图 31 所示。

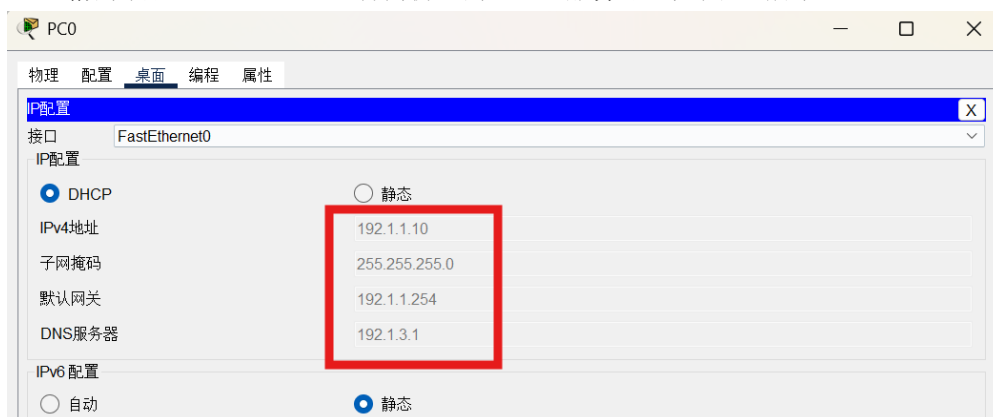


图 30 PC0 从伪造的 DHCP 服务器获取的网络信息

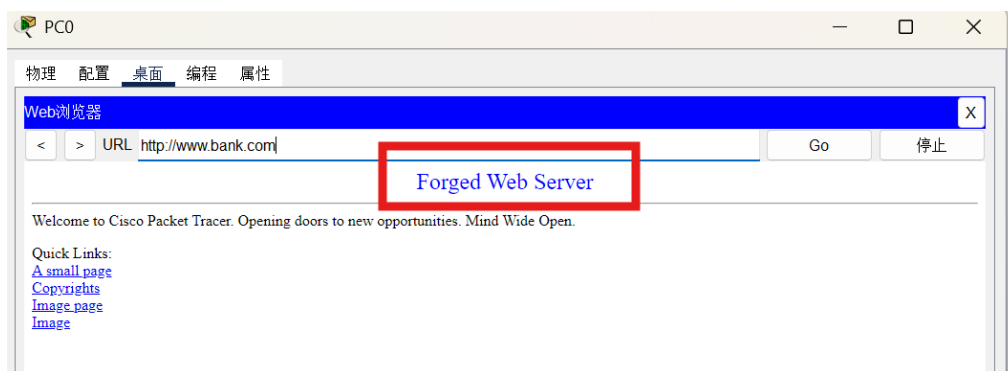


图 31 PC0 用完全合格的域名访问伪造的 Web 服务器

(3) 在 Switch0 CLI (命令行接口) 下输入用于启动交换机防 DHCP 欺骗攻击的功能的命令序列。

```

Switch>enable
Switch#conf
Switch#configure terminal
Enter configuration commands, one per line. End with CNTL/Z.
Switch(config)#ip dhcp snooping
Switch(config)#ip dhcp snooping vlan 1
Switch(config)#interface FastEthernet0/5
Switch(config-if)#ip dhcp snooping trust
Switch(config-if)#exit
Switch(config)#

```

图 32 启动交换机防 DHCP 欺骗攻击的功能

关键命令行如下：

Switch (config)#ip dhcp snooping

Switch (config)#ip dhcp snooping vlan 1

Switch (config)#interface FastEthernet0/5

Switch (config-if)#ip dhcp snooping trust

Switch (config-if)#exit

ip dhcp snooping 是全局模式下使用的命令，该命令的作用是启动 DHCP 侦听功能。DHCP 侦听功能包含两方面内容：一是通过分析经过交换机传输的 DHCP 消息，建立 DHCP 侦听信息库，侦听信息库中建立终端 MAC 地址、IP 地址与终端连接的交换机端口之间的绑定关系；二是确定只能从信任端口接收 DHCP 提供或确认消息。

ip dhcp snooping vlan 1 是全局模式下使用的命令，该命令的作用是在虚拟局域网（Virtual LAN，VLAN）1 内启动 DHCP 侦听功能。一旦在 VLAN 1 内启动 DHCP 侦听功能，默认状态下，所有属于 VLAN 1 的交换机端口都成为非信任端口，必须通过配置才能把属于 VLAN 1 的某个交换机端口设置成信任端口。值得强调的是，每一个 VLAN 必须单独启动 DHCP 侦听功能。

ip dhcp snooping trust 是接口配置模式下使用的命令，该命令的作用是将指定交换机端口（这里是 FastEthernet0/5）设置成信任端口，即允许该交换机端口接收 DHCP 提供或确认消息。FastEthernet0/5 是交换机 Switch0 连接路由器 Router1 的端口。

（4）让 PC0、PC1、PC2 再次通过 DHCP 自动获取网络信息，发现 PC0、PC1、PC2 只从 DHCP 服务器获取网络信息。如图 33 所示，PC0 得到的 DNS 服务器地址是正确的 DNS 服务器 IP 地址 192.1.2.7，从而使 PC0 用完全合格的域名 www.bank.com 访问正确的 Web 服务器，如图 34 所示。

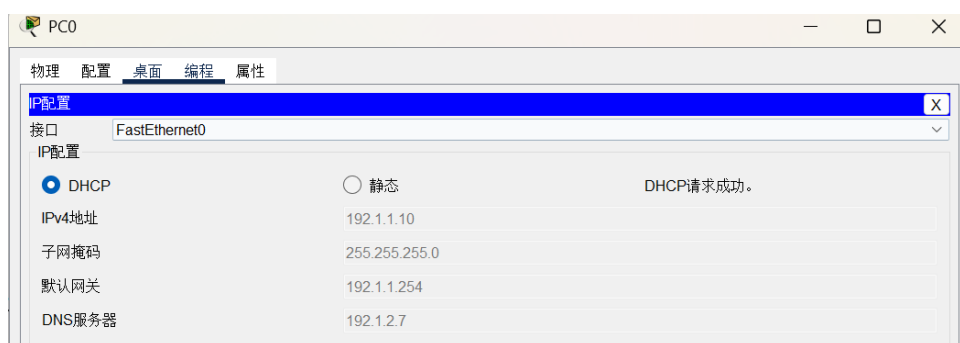


图 33 PC0 从 DHCP 服务器获取的网络信息

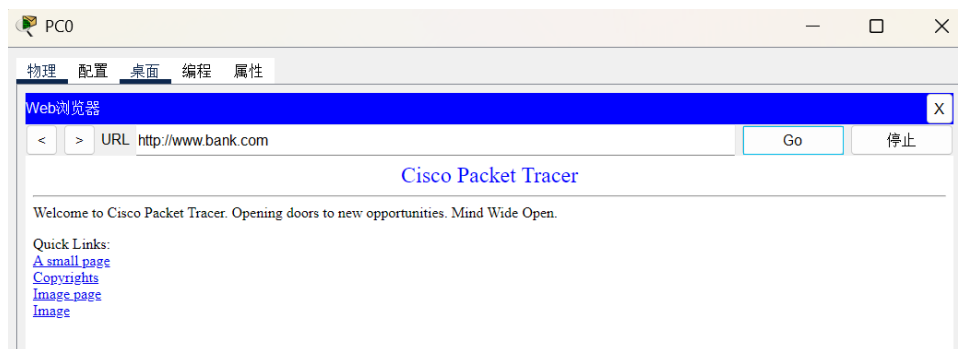


图 34 PC0 用完全合格的域名访问正确的 Web 服务器

(5) 显示 Switch0 的 DHCP 侦听信息库，得到以下三者之间的绑定关系：一是 Switch0 连接 PC0、PC1、PC2 的交换机端口；二是 PC0、PC1、PC2 的 MAC 地址；三是 DHCP 服务器分配给 PC0、PC1、PC2 的 IP 地址。如图 35 所示，FastEthernet0/1 是 Switch0 连接 PC0 的端口，00:0A:41:86:E4:D6 是 PC0 的 MAC 地址，192.1.1.10 是 DHCP 服务器分配给 PC0 的 IP 地址。

```
Switch0(Config)#exit
Switch#
%SYS-5-CONFIG_I: Configured from console by console

Switch#show ip dhcp snooping binding
MacAddress      IPAddress      Lease(sec)    Type          VLAN    Interface
-----
00:0A:41:86:E4:D6 192.1.1.10     86400         dhcp-snooping 1        FastEthernet0/1
00:60:70:28:B6:5B 192.1.1.11     86400         dhcp-snooping 1        FastEthernet0/2
00:50:0F:2A:A2:1A 192.1.1.12     86400         dhcp-snooping 1        FastEthernet0/3
Total number of bindings: 3
Switch#
```

图 35 Switch0 DHCP 侦听信息库中的内容

关键命令说明：

show ip dhcp snooping binding 是特权模式下使用的命令，该命令的作用是显示 DHCP 侦听信息库中的内容，即 MAC 地址、IP 地址和交换机端口之间的绑定关系。

本次实验使用命令列表如下：

命令格式	功能和参数说明
ip dhcp snooping	启动 DHCP 侦听功能
ip dhcp snooping vlan vlan-range	针对一个或一组 VLAN 启动 DHCP 侦听功能。参数 vlan-range 可以是单个 VLAN ID，或是多个用逗号分隔的 VLAN ID，或是一组连续的 VLAN ID
ip dhcp snooping trust	将交换机端口设置为信任端口
show ip dhcp snooping binding	显示 DHCP 侦听信息库中的内容，即 MAC 地址、IP 地址和交换机端口之间的绑定关系

表 3 防 DHCP 欺骗攻击实验关键命令

五、 实验分析总结及心得

本次四个实验都实打实验证了理论是对的：访问控制列表实验里，交换机端口 1 静态绑了终端 A 的 MAC，A 插上去发消息能正常通，换成终端 B 一插，端口直接关了，得用 “shutdown” 再 “no shutdown” 才能重新开；安全端口实验我把最大 MAC 数设成 2，终端 A、B 先后接上后，用 “show port-security address” 能看到它们的 MAC 在列表里，再插终端 C，它发的帧直接被丢了，连不上网；MAC 地址欺骗实验中，终端 C 改了自己的 MAC 为 MAC A 后，终端 B 发往 MAC A 的消息真就跑到 C 那儿去了，用 “show mac-address-table” 看转发表，果然通往 MAC A 的条目指向了 C 的端口；防 DHCP 欺骗实验里，一开始只在交换机全局开了 “ip dhcp snooping vlan 1”，结果终端还是能拿到伪造 DHCP 的地址，后来给连接路由器的 Fa0/4 口设了 “ip dhcp snooping trust”，终端才只认合法 DHCP 服务器的配置，没再跳转到假 Web 页。实验时踩了不少坑：比如配置端口安全时，我忘了进接口模式，直接在全局模式输 “switchport port-security”，结果命令报错，查了教材才反应过来这类接口级命令得先切到 “config-if” 模式，其他还有一些都是细节上的问题，总的实验做起来还是比较清晰的，书本上的介绍给的很详细，照着做就好了，在对照着做的过程中加深了课本知识的印象，对实验背后的原理有了更加清楚的认知。

实验四 网络攻击原理分析与验证实验

一、 实验目的

1. 利用思科 Packet tracer 软件模拟实现利用相关协议进行攻击的实验；
2. 防生成树欺骗攻击实验。
 - (1) 验证交换机优先级对构建的生成树的影响
 - (2) 验证生成树欺骗攻击过程
 - (3) 验证防生成树欺骗攻击原理
 - (4) 验证防生成树欺骗攻击实现过程
3. **钓鱼攻击与防御实验（必做）。**
 - (1) 验证伪造的 DHCP 服务器为终端提供网络信息配置服务的过程
 - (2) 验证错误的本地域名服务器地址造成的后果
 - (3) 验证利用网络实施钓鱼网站的过程

二、 实验原理

1.生成树协议的安全缺陷？

生成树协议的安全缺陷主要源于缺乏原生认证机制、拓扑决策依赖未加密的桥协议数据单元（BPDU），以及默认配置的脆弱性：攻击者可通过伪造高优先级 BPDU 实施根桥欺骗，抢占根桥地位后劫持网络流量；或发送大量无效 BPDU 引发泛洪攻击，耗尽交换机 CPU 与内存资源导致拓扑不稳定；还可篡改 BPDU 中的优先级、端口成本等参数，非法修改网络拓扑结构，造成流量绕行、中断或转发环路；此外，STP 默认允许所有端口参与拓扑计算，未限制 BPDU 接收端口，易被攻击者接入网络后利用上述漏洞发起攻击，且传统 STP 收敛速度较慢，攻击过程中可能导致网络长时间不可用。

2.DHCP 协议的安全缺陷？

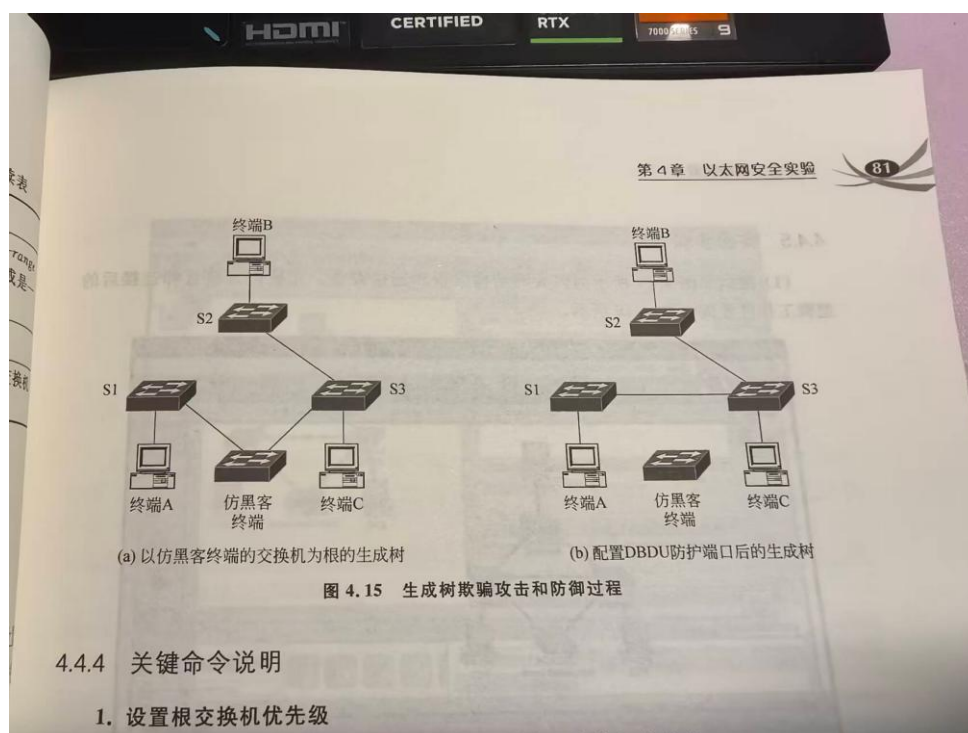
DHCP 协议的安全缺陷主要源于缺乏原生身份认证机制、消息明文传输特性及配置灵活性带来的风险：协议未对 DHCP 服务器与客户端的身份进行验证，攻击者可伪造 DHCP 服务器发送恶意配置，实施 DHCP 欺骗攻击，导致客户端流量被劫持或接入钓鱼网络；DHCP 消息以明文传输，易被嗅探窃取，为后续攻击提供信息支撑；攻击者可发送大量伪造的 DHCP 请求报文耗尽服务器 IP 地址池，造成合法客户端无法获取网络配置的地址耗尽攻击；同时，DHCP 中继代理配置不当可能被滥用转发恶意 DHCP 消息，扩大攻击影响范围，且租约管理机制缺乏严格校验，恶意客户端可通过伪造租约更新请求长期占用 IP 资源，导致网络资源浪费。

3.实施钓鱼攻击的方式有哪些？

实施钓鱼攻击的方式主要包括：通过伪造银行、运营商、企业等官方机构的邮件、短信或语音，附带诱导性文案与恶意链接 / 附件，诱骗用户点击进入钓鱼网站或下载恶意程序；搭建仿冒官方网站，通过虚假登录界面、中奖通知等窃取用户账号密码、银行卡信息等敏感数据；利用社交媒体、即时通讯工具伪装成熟人、客服或权威人士，以求助、业务办理、退款理赔等名义诱导转账或泄露个人信息；借助恶意广告、搜索引擎优化将钓鱼网站伪装成正规站点提高曝光度，或通过供应链攻击在合法软件、文档中植入钓鱼链接，甚至利用二维码、U 盘等线下载体诱导用户扫描或插入设备，最终实现信息窃取、财产诈骗或植入恶意软件的目的。

4.防生成树欺骗攻击实验原理：

将仿黑客终端的交换机的优先级设置为最高后，根据如图 4.14 所示的以太网结构构建的生成树如图 4.15 (a) 所示，仿黑客终端的交换机成为根交换机，终端 A 与终端 B 和终端 C 之间传输的数据经过仿黑客终端的交换机。将交换机 S1 和 S3 连接仿黑客终端的交换机的端口设置为 BPDU 防护端口后，仿黑客终端的交换机一旦发送 BPDU，交换机 S1 和 S3 将关闭连接仿黑客终端的交换机的端口，导致仿黑客终端的交换机不再与网络相连，仿黑客终端的交换机不再成为如图 4.15 (b) 所示的重新构建的生成树的一部分，终端之间传输的数据不再经过仿黑客终端的交换机。



5. 钓鱼攻击与防御实验原理:

终端通过广播 DHCP 发现消息发现 DHCP 服务器，当 DHCP 服务器与终端不在同一个网络 (同一个广播域) 时，由路由器完成中继过程。DHCP 服务器通过向终端发送 DHCP 提供消息表明可以为终端提供网络信息配置服务，终端选择发送第一个到达终端的 DHCP 提供消息的 DHCP 服务器为其提供网络信息配置服务。如图 2.38 所示，在终端连接的网络中接入伪造的 DHCP 服务器后，终端广播的 DHCP 发现消息到达伪造的 DHCP 服务器，伪造的 DHCP 服务器在网络中广播 DHCP 提供消息，由于伪造的 DHCP 服务器与终端位于同一网络，伪造的 DHCP 服务器发送的 DHCP 提供消息可能先于 DHCP 服务器发送的 DHCP 提供消息到达终端，导致终端选择伪

造的 DHCP 服务器为其提供网络信息配置服务,并将伪造的 DNS 服务器的 IP 地址 192.1.3.1 作为本地域名服务器地址。

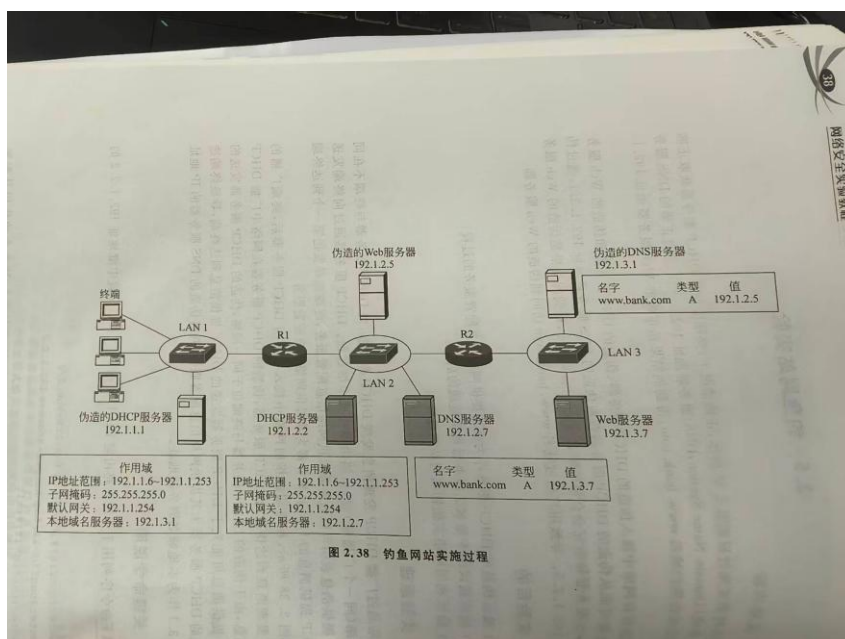


图 2.38 钓鱼网站实施过程

三、 实验环境/实验拓扑图

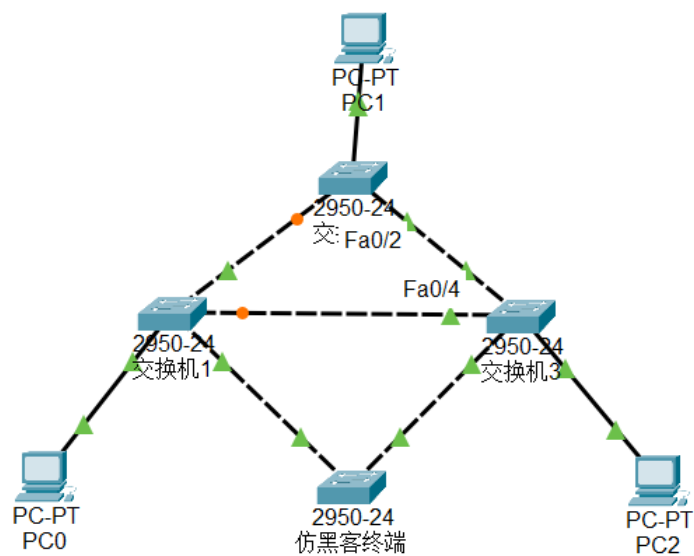


图 1 防生成树欺骗攻击实验拓扑图

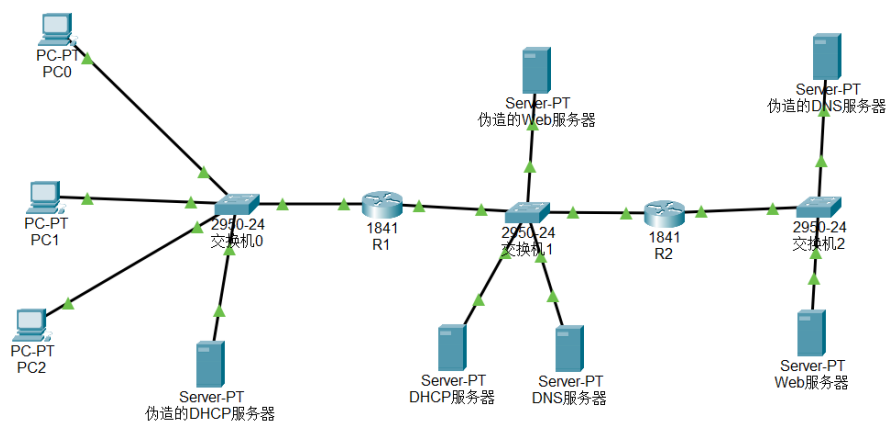


图 2 钓鱼网站实验拓扑图

四、 主要操作步骤及实验结果记录

（对实验过程中的主要操作步骤进行描述，并随时记录实验过程中观察到的结果，必要时可辅助截图）
防生成树欺骗攻击实验：

（1）根据课本上图 4.14 所示的以太网结构放置和连接设备。完成设备放置和连接后的逻辑工作区界面如图 3 所示。

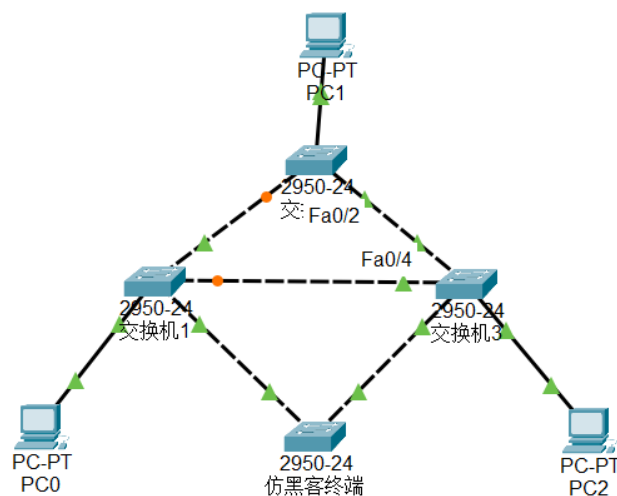


图 3 实验拓扑图

（2）完成终端网络信息配置过程。通过在 CLI(命令行接口) 下输入用于指定交换机生成树工作模式和交换机优先级的命令序列，将仿黑客终端的交换机 (simulated hack) 配置成根交换机。

```
%LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/2, changed st

Switch>enable
Switch#confi
Switch#configure terminal
Enter configuration commands, one per line. End with CNTL/Z.
Switch(config)#spanning-tree mode pvst
Switch(config)#spanning-tree vlan 1 root primary
Switch(config)#
```

图 4 将仿黑客终端配置成根交换机

关键命令说明：

设置根交换机优先级

以下命令序列用于指定交换机生成树工作模式和交换机优先级。

Switch (config)#spanning-tree mode pvst

Switch (config)#spanning-tree vlan 1 root primary

spanning-tree mode pvst 是全局模式下使用的命令，该命令的作用是将交换机生成树协议的工作模式指定为基于 VLAN 的生成树 (Per-Vlan Spanning Tree,PVST) 模式。PVST (基于 VLAN 的生成树) 模式是 Cisco 最基本的生成树工作模式，它为每一个 VLAN 构建独立的生成树。

spanning-tree vlan 1 root primary 是全局模式下使用的命令，该命令的作用是将交换机设置成基于 VLAN 1 的生成树的根网桥。该命令的实际作用是将交换机在构建基于 VLAN 1 的生成树中所具有的优先级指定为一个小于默认值的特定值。

(3) 完成生成树构建过程后，切换到模拟操作模式，启动 PC0 至 PC1 ICMP 报文传输过程，发现 PC0 至 PC1 ICMP 报文经过仿黑客终端的交换机，如图 5 所示。（注意！这里要先为 PC0,PC1,PC2 配置网络信息）

PC0:IP-192.1.1.1

PC1:IP-192.1.1.2

PC2:IP-192.1.1.3

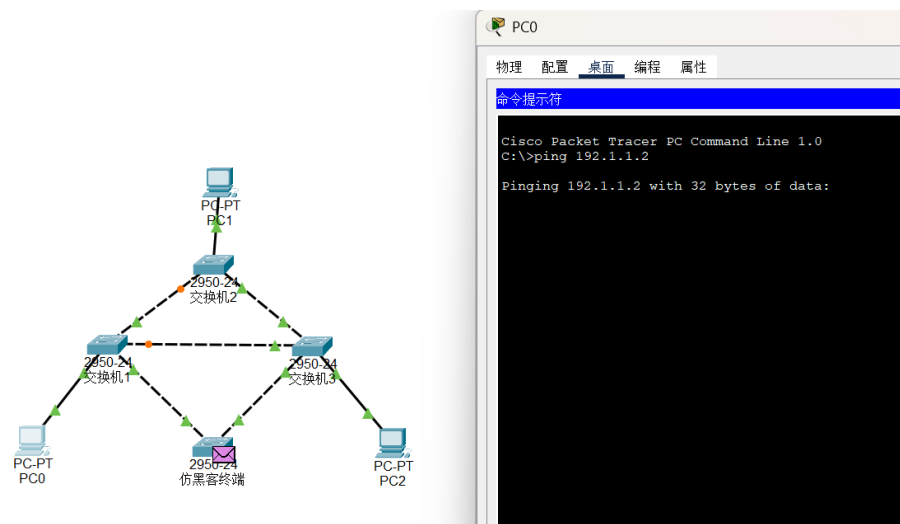


图 5 仿黑客终端的交换机为根交换机的生成树

(4) 通过在 CLI(命令行接口) 下输入用于将交换机端口设置为 BPDU 防护端口的命令序列，将交换机 Switch1 和 Switch3 连接仿黑客终端的交换机的端口 (这里是 FastEthernet0/2) 设置为 BPDU 防护端口。仿黑客终端的交换机一旦向交换机 Switch1 和 Switch3 发送 BPDU，交换机 Switch1 和 Switch3 立即关闭连接仿黑客终端的交换机的端口 (这里是 FastEthernet0/2)，使仿黑客终端的交换机与以太网分离。

```

Switch>enable
Switch#con
Switch#conf
Switch#configure termina
Switch#configure terminal
Enter configuration commands with CNTL/Z.
Switch(config)#spanning-tree mode pvst
Switch(config)#interface FastEthernet0/2
Switch(config-if)#spanning-tree bpduguard enable
Switch(config-if)#spanning-tree bpduguard: Received BPDU on port FastEthernet0/2 with BPDU
Guard enabled. Disabling port.

%PM-4-ERR_DISABLE: bpduguard error detected on 0/2, putting 0/2 in err-disable state

%LINK-5-CHANGED: Interface FastEthernet0/2, changed state to administratively down
%LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/2, changed state to down
exit
Switch(config)#

```

复制

粘贴

图 6 为 Switch1 配置防护端口

关键命令说明：

设置 BPDU 防护端口

以下命令序列用于将交换机端口 FastEthernet0/2 设置为 BPDU 防护端口。

Switch (config)#interface FastEthernet0/2

Switch (config-if)#spanning-tree bpduguard enable

Switch (config-if)#exit

spanning-tree bpduguard enable 是接口配置模式下使用的命令，该命令的作用是将交换机端口（这里是 FastEthernet0/2）设置为 BPDU 防护端口。某个端口设置为 BPDU 防护端口后，一旦通过该端口接收到 BPDU，交换机将立即关闭该端口。可以通过输入一组特殊的命令序列重新开启该端口。

（5）仿黑客终端的交换机不再成为重新构建的生成树的组成部分。切换到模拟操作模式，启动 PC0 至 PC1 ICMP 报文传输过程，发现 PC0 至 PC1 的 ICMP 报文不再经过仿黑客终端的交换机，如图 7 所示。

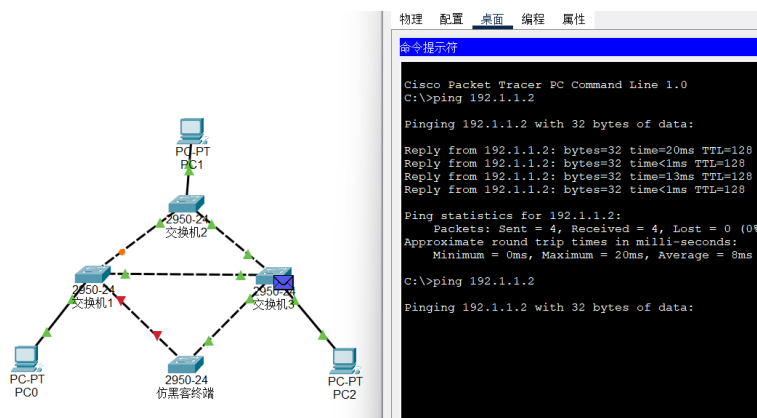


图 7 重新构建的生成树

本次实验使用到的全部关键命令如下：

命令格式	功能和参数说明
spanning-tree mode { pvst rapid-pvst }	设置交换机生成树协议工作模式，可以选择的工作模式有 pvst 和 rapid-pvst
spanning-tree vlan vlan-id priority priority	设置交换机构建基于 VLAN 的生成树时具有的优先级。参数 vlan-id 用于指定 VLAN，参数 priority 用于指定优先级
spanning-tree vlan vlan-id root primary	将交换机设置成基于 VLAN 的生成树的主根交换机。参数 vlan-id 用于指定 VLAN
spanning-tree bpduguard {disable enable}	enable 选项用于将端口设置为 BPDU 防护端口，disable 选项用于将端口从 BPDU 防护端口还原为普

通端口。某个端口设置为 BPDU 防护端口后，一旦通过该端口接收到 BPDU，交换机将立即关闭该端口

表 1 防生成树欺骗攻击实验命令列表

钓鱼网站实验:

(1) 实现正常的 Web 服务器访问过程,因此,在如课本上图所示的网络结构中去掉所有伪造的服务器,根据去掉所有伪造的服务器后的网络结构放置和连接设备。完成设备放置和连接后的逻辑工作区界面如下图所示。

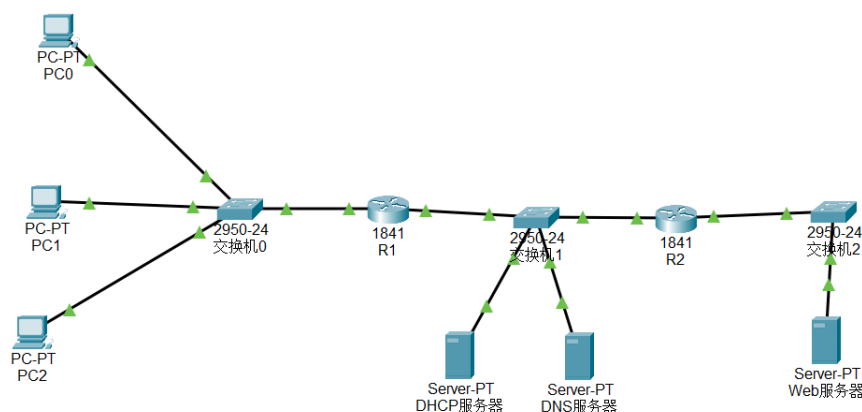


图 8 实验拓扑图

(2)完成路由器接口 IP 地址和子网掩码配置过程,完成路由器 RIP 配置过程。路由器 Router1 和 Router2 建立完整路由表。

Router1 命令行接口配置命令:

```
Router>enable # 从用户模式切换到特权模式，获取设备配置操作权限
Router#configure terminal # 进入全局配置模式，用于配置设备全局参数
Router(config)#interface FastEthernet0/0 # 进入 FastEthernet0/0 接口的配置模式
Router(config-if)#no shutdown # 启用当前接口（默认可能关闭），使其处于工作状态
Router(config-if)#ip address 192.1.1.254 255.255.255.0 # 为 FastEthernet0/0 接口配置 IP 地址 192.1.1.254 和子网掩码 255.255.255.0，作为 192.1.1.0 网段的网关
Router(config-if)#exit # 退出当前接口配置模式，返回全局配置模式
Router(config)#interface FastEthernet0/1 # 进入 FastEthernet0/1 接口的配置模式
Router(config-if)#no shutdown # 启用 FastEthernet0/1 接口，使其处于工作状态
Router(config-if)#ip address 192.1.2.254 255.255.255.0 # 为 FastEthernet0/1 接口配置 IP 地址 192.1.2.254 和子网掩码 255.255.255.0，作为 192.1.2.0 网段的网关
Router(config-if)#exit # 退出 FastEthernet0/1 接口配置模式，返回全局配置模式
Router(config)#router rip # 启用 RIP（路由信息协议），用于设备间动态学习路由
Router(config-router)#network 192.1.1.0 # 向 RIP 协议宣告 192.1.1.0 网段，告知该网段需参与路由更新与同步
Router(config-router)#network 192.1.2.0 # 向 RIP 协议宣告 192.1.2.0 网段，参与路由更新与同步
Router(config-router)#exit # 退出 RIP 路由协议配置模式，返回全局配置模式
Router(config)#interface FastEthernet0/0 # 再次进入 FastEthernet0/0 接口配置模式
Router(config-if)#ip helper-address 192.1.2.2 # 配置 DHCP 中继地址为 192.1.2.2（DHCP 服务器 IP），将该接口收到的 DHCP 广播消息转发至指定 DHCP 服务器
```

Router(config-if)#exit # 退出 FastEthernet0/0 接口配置模式

Router2 命令行接口配置命令:

Router>enable # 从用户模式切换到特权模式, 获取设备配置操作权限

Router#configure terminal # 进入全局配置模式, 用于配置设备全局参数

Router(config)#interface FastEthernet0/0 # 进入 FastEthernet0/0 接口的配置模式

Router(config-if)#no shutdown # 启用当前接口, 使其处于工作状态

Router(config-if)#ip address 192.1.2.253 255.255.255.0 # 为 FastEthernet0/0 接口配置 IP 地址 192.1.2.253 和子网掩码 255.255.255.0, 用于接入 192.1.2.0 网段

Router(config-if)#exit # 退出当前接口配置模式, 返回全局配置模式

Router(config)#interface FastEthernet0/1 # 进入 FastEthernet0/1 接口的配置模式

Router(config-if)#no shutdown # 启用 FastEthernet0/1 接口, 使其处于工作状态

Router(config-if)#ip address 192.1.3.254 255.255.255.0 # 为 FastEthernet0/1 接口配置 IP 地址 192.1.3.254 和子网掩码 255.255.255.0, 作为 192.1.3.0 网段的网关

Router(config-if)#exit # 退出 FastEthernet0/1 接口配置模式, 返回全局配置模式

Router(config)#router rip # 启用 RIP (路由信息协议), 用于设备间动态学习路由

Router(config-router)#network 192.1.2.0 # 向 RIP 协议宣告 192.1.2.0 网段, 告知该网段需参与路由更新与同步

Router(config-router)#network 192.1.3.0 # 向 RIP 协议宣告 192.1.3.0 网段, 参与路由更新与同步

Router(config-router)#exit # 退出 RIP 路由协议配置模式

关键命令格式	功能和参数说明
ip helper-address address	一是配置 DHCP 服务器的 IP 地址, 二是启动接口的 DHCP 中继功能。参数 address 给出 DHCP 服务器的 IP 地址

表 2 命令列表

(3) 完成路由器 Router1 接口 FastEthernet0/0 的中继地址配置过程。该配置过程只能通过 CLI(命令行接口)下输入下图 9 中给出的用于完成中继地址配置过程的命令序列实现。

```
%LINK-5-CHANGED: Interface FastEthernet0/1, changed state to up
%LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/1, changed state

Router(config-if)#ip address 192.1.2.254 255.255.255.0
Router(config-if)#exit
Router(config)#router rip
Router(config-router)#network 192.1.1.0
Router(config-router)#network 192.1.2.0
Router(config-router)#exit
Router(config)#interface FastEthernet0/0
Router(config-if)#ip helper-address 192.1.2.2
Router(config-if)#exit
```

图 9 配置中继地址

(4) 按照课本图 2.38 所示的服务器 IP 地址,完成 3 台服务器 IP 地址、子网掩码和默认网关地址配置过程,服务器的默认网关地址是路由器连接服务器所在网络的接口的 IP 地址。由于 Router1 和 Router2 各有一个接口连接 DHCP 服务器和 DNS 服务器所在的网络,DHCP 服务器和 DNS 服务器可以选择其中一个接口的 IP 地址作为默认网关地址。配置如下图

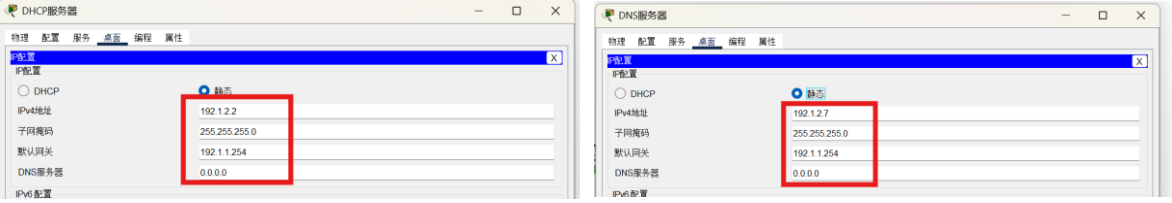


图 10 DHCP 服务器配置

图 11 DNS 服务器配置

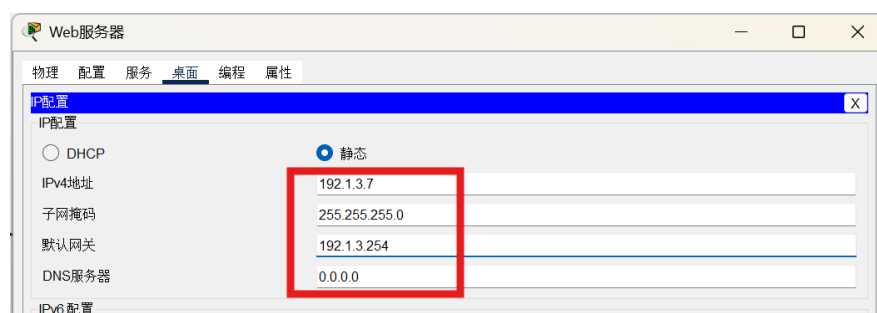


图 12 Web 服务器配置

(5) 完成 DHCP 服务器 “Services(服务)” → “DHCP” 操作过程,弹出如图 13 所示的 DHCP 服务器作用域配置界面,Service(服务)一栏选择 On。serverPool 是 Pool Name(作用域名),每一个作用域需要取不同的作用域名。192.1.1.254 是该作用域的 Gateway(默认网关)地址、192.1.2.7 是该作用域的 DNS Server(DNS 服务器)地址,Start IP Address(起始 IP 地址)192.1.1.10 和 Maximum number of User(最大用户数)50 确定可分配的 IP 地址范围是 192.1.1.10~192.1.1.59。



图 13 DHCP 服务器作用域配置界面

(6) 完成 DNS 服务器 “Services(服务)” → “DNS” 操作过程,弹出如图 14 所示的 DNS 服务器资源记录配置界面,DNS Service(DNS 服务)一栏选择 On。在 Name(名字)框中输入完全合格的域名 www.bank.com,Type(类型)选择 A Record(A 记录类型),在 Address(地址)框中输入完全合格的域名为 www.bank.com 的 Web 服务器的 IP 地址 192.1.3.7。

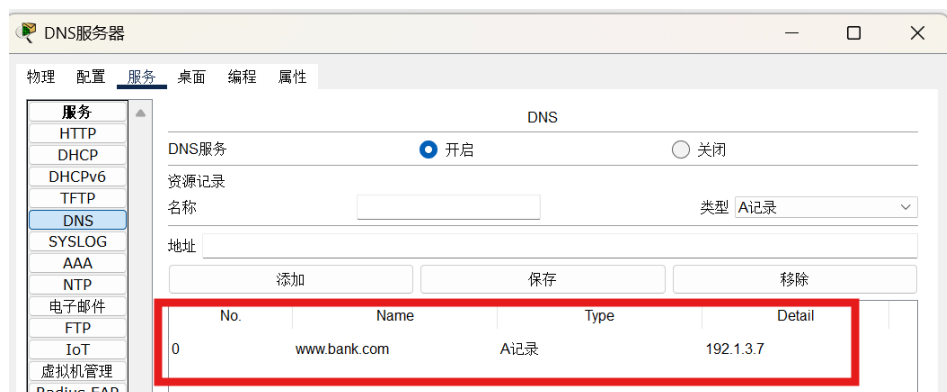


图 14 DNS 服务器资源记录配置

(7) 完成 PC0 “Desktop(桌面)” → “IP Configuration(IP 配置)” 操作过程,弹出如图 15 所示的 PC0 网络

信息配置界面,选择 DHCP 选项,PC0 自动获取如图 15 所示的网络信息。其中 IP 地址是 DHCP 服务器中名为 serverPool 的作用域定义的 IP 地址范围 192.1.1.10~192.1.1.59 中按照大小顺序选取的 IP 地址 192.1.1.10。子网掩码、默认网关和 DNS 服务器地址与名为 serverPool 的作用域定义子网掩码、默认网关地址和 DNS 服务器地址相同。

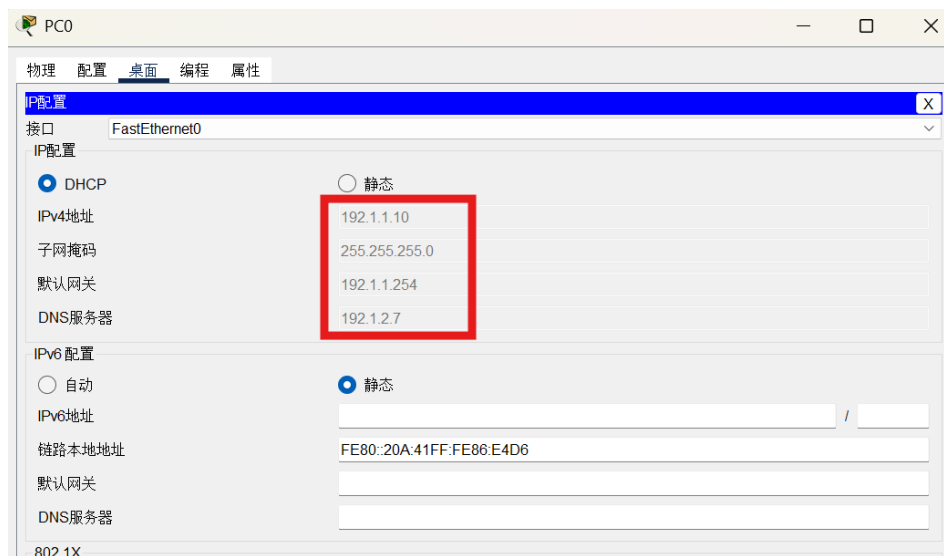


图 15 PC0 自动获取的网络信息

(8) 完成 PC0 “Desktop(桌面)” → “Web Browser(浏览器)” 操作过程,弹出如图 16 所示的浏览器使用界面,在 URL 栏中输入完全合格的域名 www.bank.com,单击 Go,成功访问到完全合格的域名为 www.bank.com 的 Web 服务器。

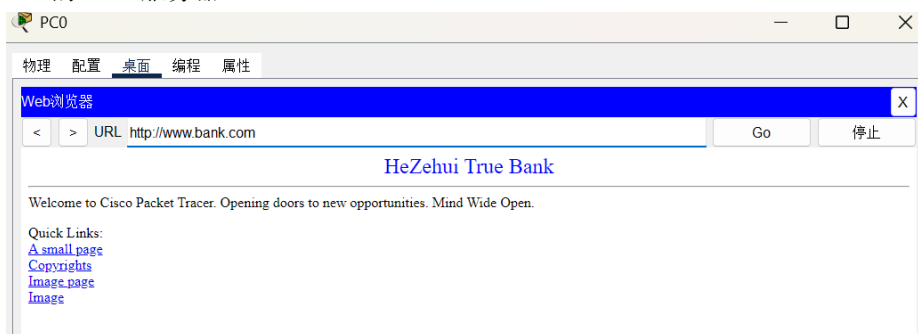


图 16 PC0 通过 www.bank.com 成功访问 Web 服务器界面

(9) 接入 3 台伪造的服务器,逻辑工作区界面如图 17 所示。完成 3 台伪造的服务器的 IP 地址、子网掩码和默认网关地址配置过程如图 18 所示。完成伪造的 DHCP 服务器的作用域配置过程,配置的作用域信息如图 19 所示;完成伪造的 DNS 服务器的资源记录配置过程,配置的资源记录如图 20 所示。让 PC0 再次自动获取网络信息,获取的网络信息如图 21 所示,DNS 服务器地址是伪造的 DNS 服务器的 IP 地址 192.1.3.1,表明 PC0 从伪造的 DHCP 服务器获取网络信息。

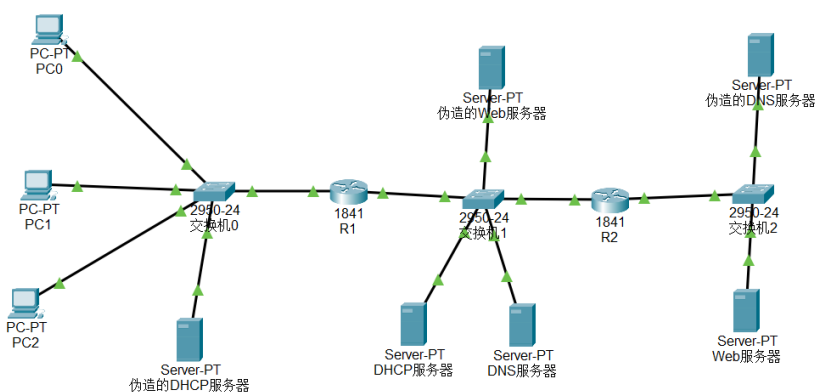


图 17 接入伪造的服务器后的逻辑工作区界面

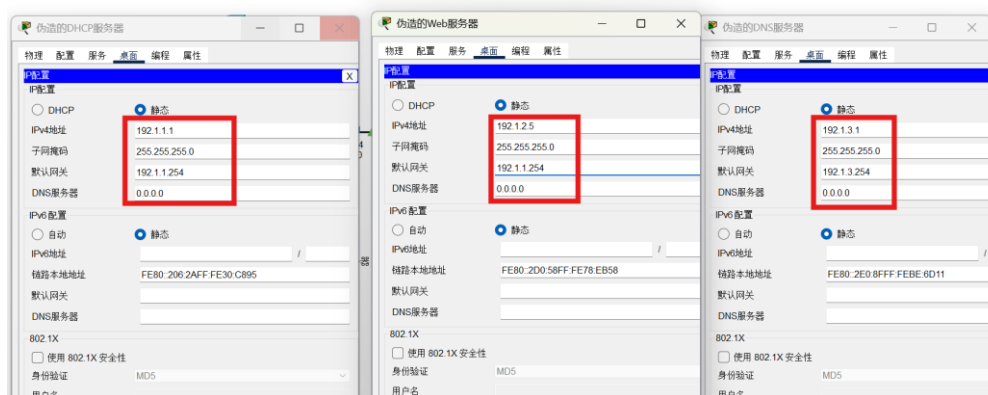


图 18 伪造服务器网络信息配置

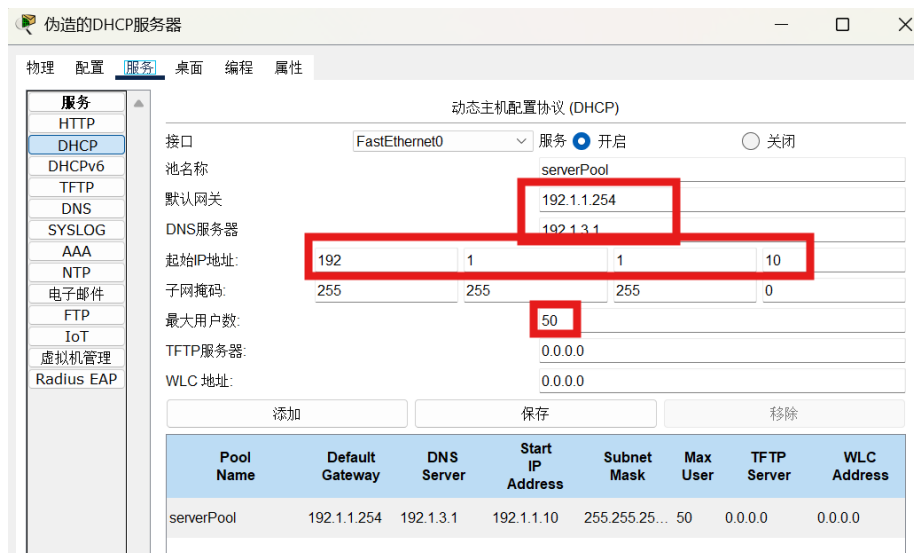


图 19 伪造的 DHCP 服务器作用域配置界面

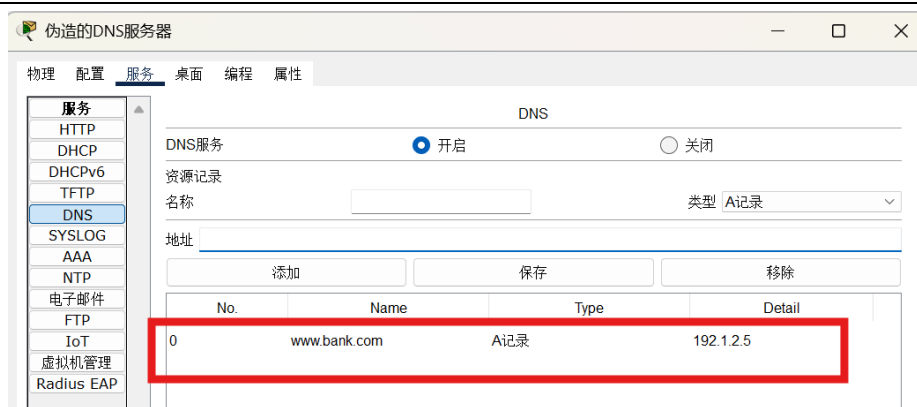


图 20 伪造的 DNS 服务器资源记录配置界面

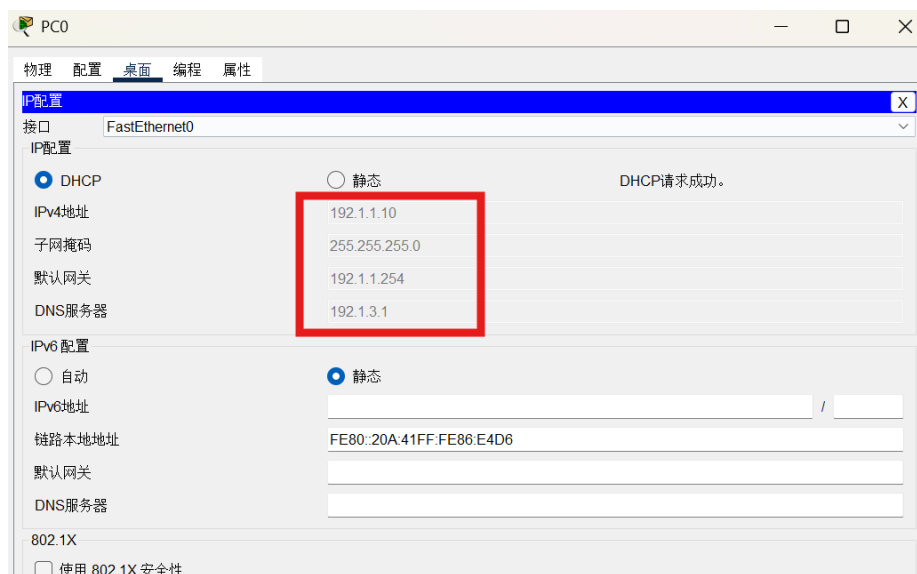


图 21 PC0 从伪造的 DHCP 服务器获取的网络信息

(10) 让 PC0 再次用浏览器访问完全合格的域名为 www.bank.com 的 Web 服务器,访问结果如图 22 所示,访问结果表明 PC0 访问的是伪造的 Web 服务器。

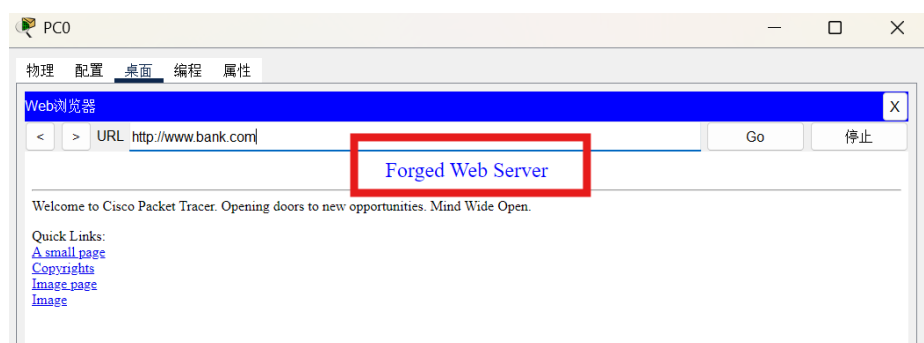


图 22 PC0 通过 www.bank.com 访问伪造的 Web 服务器界面

五、 实验分析总结及心得

这两个实验都把理论实操验证得很清楚：防生成树欺骗攻击实验中，先给仿黑客终端的交换机用 “spanning-tree vlan 1 root primary” 设为 VLAN1 的根交换机，用 “show spanning-tree root” 查看确认后，PC0 ping PC1 的 ICMP 报文果然经过了这台仿黑客交换机；接着进 S1 和 S3 连接它的 FastEthernet0/4 接口，输 “spanning-tree bpduguard enable” 设为 BPDU 防护端口，仿黑客交换机一发送 BPDU，那两个端口立马变成 err-disabled 状态，再 ping 时报文路径就绕开了它，生成树也重新构建了。钓鱼攻击与防御实验里（[这里的实验主要是攻击，防御的话在上一节的防 DHCP 欺骗攻击实验中](#)），没开防御前，接入伪造 DHCP 服务器后，终端的 DHCP 发现消息先被伪造服务器接收，它发的 offer 比合法 DHCP 服务器的先到，终端拿到假 DNS 地址 192.1.3.1，访问 www.bank.com 直接跳伪造 Web 页；实验时也遇到过一些问题：钓鱼实验里信任端口配错，没理清 “信任端口要对应合法 DHCP 消息的传输路径”，想当然选了终端所在端口，导致后面无法达到预期效果。这两个实验让我真正懂了生成树根网桥选举靠优先级、BPDU 防护是通过关端口阻断恶意设备，也明白 DHCP 欺骗防御不是光开侦听功能就行，信任端口的精准配置才是关键。

附加实验 Smurf 攻击实验

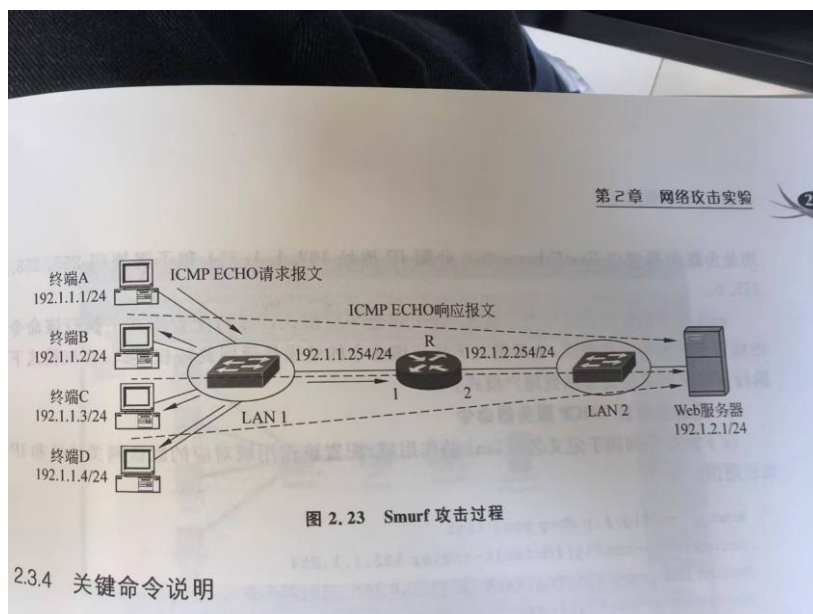
一、实验目的

- （1）验证 ICMP ECHO 请求、响应过程。
- （2）验证网络放大 ICMP ECHO 响应报文的过程。
- （3）验证接收攻击原理。
- （4）验证 Smurf 攻击过程。

二、实验原理

Smurf 攻击过程如图 2.23 所示，终端 A 将 ICMP ECHO 请求报文封装成以 Web 服务器的 IP 地址为源 IP 地址、以全 1 广播地址为目的 IP 地址的 IP 分组，该 ICMP ECHO 请求报文到达 LAN 1 中的所有其他终端和路由器 R，接收到该 ICMP ECHO 请求报文的终端均发送 ICMP ECHO 响应报文，这些 ICMP ECHO 响应报文都被封装成以 Web 服务器的 IP 地址为目的 IP 地址的 IP 分组，导致这些 ICMP ECHO 响应报文全部到达 Web 服务器。由于 LAN 1 中接入大量终端（这里是四个终端），为避免为每个终端配置网络信息，启动路由器 R 的动态主机配置协议 (Dynamic Host Configuration Protocol,DHCP) 服务器功能，由路由器 R 自动为接入

LAN 1 的终端配置网络信息。



三、实验环境/实验拓扑图

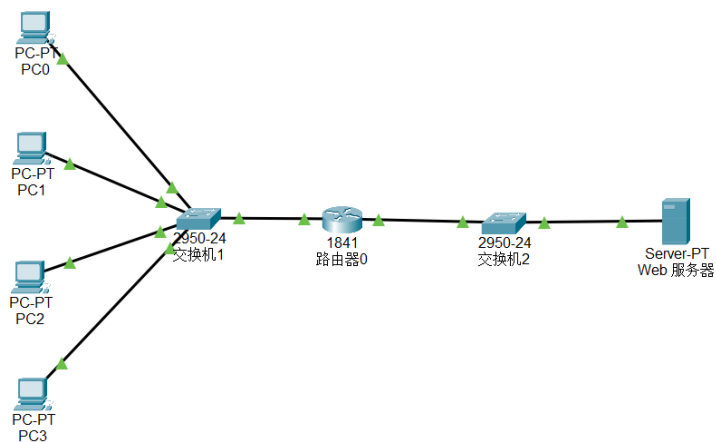


图 1 Smurf 攻击实验拓扑图

四、主要操作步骤及实验结果记录

(1) 完成设备放置和连接过程。根据书本图 2.22 所示的互连网结构放置和连接设备。完成设备放置和连接后的逻辑工作区界面如图 2 所示。

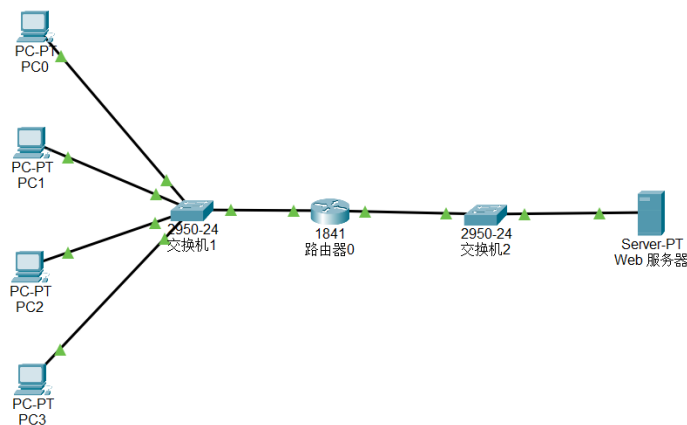


图 2 实验拓扑图

(2) 完成路由器 Router “Config (配置)” → “FastEthernet0/0 (FastEthernet0/0 接口)” 操作过程，弹出如图 2.25 所示的路由器 Router FastEthernet0/0 接口配置界面。在 Port Status (端口状态) 中勾选 On。在 IP Address (IP 地址) 中输入 FastEthernet0/0 接口的 IP 地址 192.1.1.254，在 Subnet Mask (子网掩码) 中输入 FastEthernet0/0 接口的子网掩码 255.255.255.0。完成路由器 Router FastEthernet0/0 接口的配置过程。用同样的方式完成 Router FastEthernet0/1 接口的配置过程。

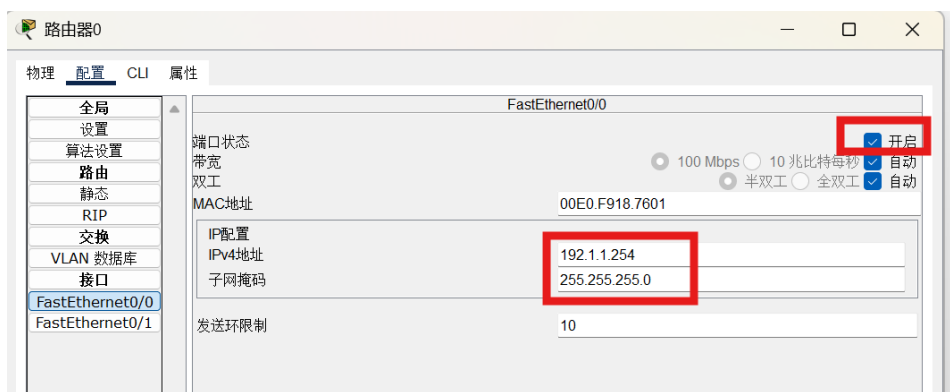


图 3 路由器 FastEthernet0/0 接口配置界面

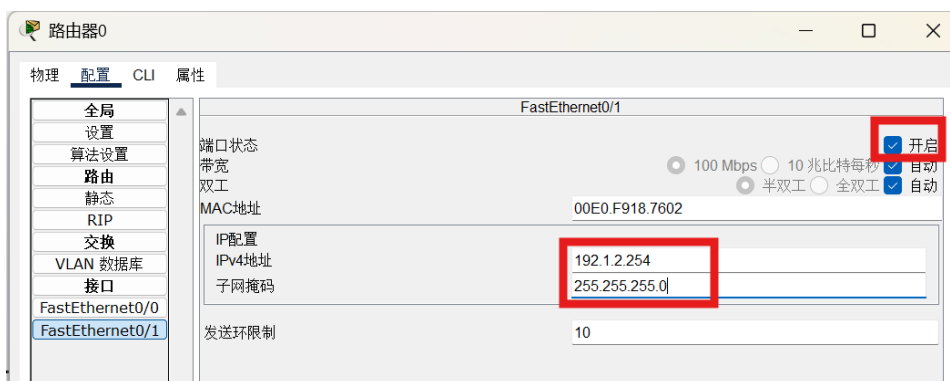
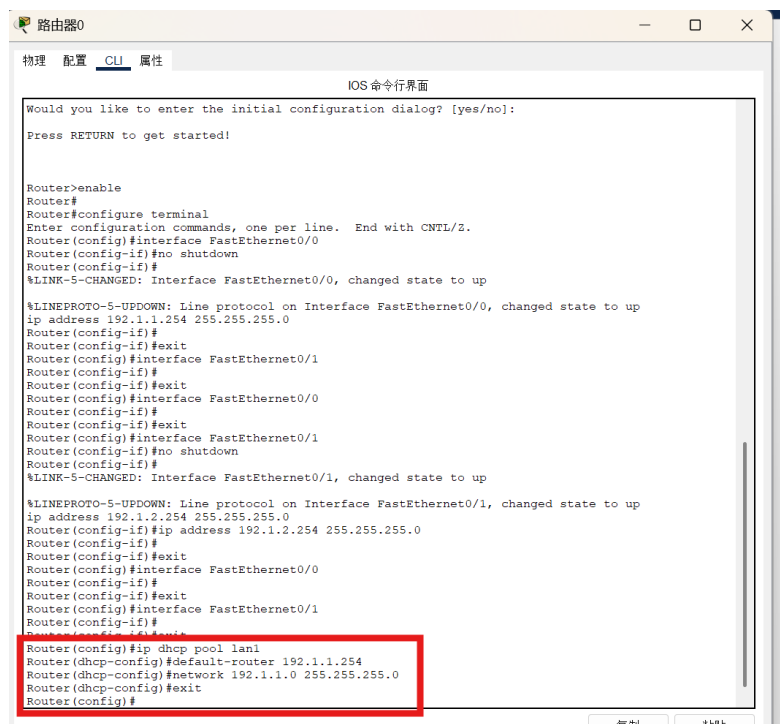


图 4 路由器 FastEthernet0/1 接口配置界面

(3) 完成路由器 Router DHCP 服务器配置过程，该配置过程需要通过在 CLI (命令行接口) 中输入书本第 2.3.4 节中给出的用于完成路由器 DHCP 服务器配置过程的命令序列完成。这也说明，图形配置界面只能完成简单功能的配置过程，复杂功能的配置过程需要通过 CLI (命令行接口) 实现，如图 5 所示。



```
Would you like to enter the initial configuration dialog? [yes/no]:
Press RETURN to get started!

Router>enable
Router#
Router#configure terminal
Enter configuration commands, one per line. End with CNTL/Z.
Router(config)#interface FastEthernet0/0
Router(config-if)#no shutdown
Router(config-if)#
%LINK-5-CHANGED: Interface FastEthernet0/0, changed state to up
%LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/0, changed state to up
ip address 192.1.1.254 255.255.255.0
Router(config-if)#
Router(config-if)#exit
Router(config)#interface FastEthernet0/1
Router(config-if)#
Router(config-if)#exit
Router(config)#interface FastEthernet0/0
Router(config-if)#
Router(config-if)#exit
Router(config)#interface FastEthernet0/1
Router(config-if)#no shutdown
Router(config-if)#
%LINK-5-CHANGED: Interface FastEthernet0/1, changed state to up
%LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/1, changed state to up
ip address 192.1.2.254 255.255.255.0
Router(config-if)#ip address 192.1.2.254 255.255.255.0
Router(config-if)#
Router(config-if)#exit
Router(config)#interface FastEthernet0/0
Router(config-if)#
Router(config-if)#exit
Router(config)#interface FastEthernet0/1
Router(config-if)#
Router(config-if)#exit
Router(config)#ip dhcp pool lan1
Router(dhcp-config)#default-router 192.1.1.254
Router(dhcp-config)#network 192.1.1.0 255.255.255.0
Router(dhcp-config)#exit
Router(config)#
```

图 5 路由器 DHCP 服务配置

以下命令序列用于定义名为 lan1 的作用域，配置该作用域对应的默认网关地址和 IP 地址范围。

Router(config)#ip dhcp pool lan1

Router(dhcp-config)#default-router 192.1.1.254

Router(dhcp-config)#network 192.1.1.0 255.255.255.0

Router(dhcp-config)#exit

ip dhcp pool lan1 是全局模式下使用的命令，该命令的作用有两个，一是创建名为 lan1 的作用域；二是进入 DHCP 配置模式，在 DHCP 配置模式下完成该作用域相关网络信息的配置过程。

default-router 192.1.2.254 是 DHCP 配置模式下使用的命令，(dhcp-config)# 是 DHCP 配置模式下的命令提示符。该命令的作用是将 192.1.2.254 作为该作用域的默认网关地址。如果该作用域作用于某个网络，将路由器连接该网络的接口的 IP 地址作为该作用域的默认网关地址，如名为 lan1 的作用域是作用于以太网 LAN 1 的作用域，路由器连接 LAN 1 的接口的 IP 地址作为该作用域的默认网关地址。

network 192.1.1.0 255.255.255.0 是 DHCP 配置模式下使用的命令，该命令的作用是将 IP 地址范围指定为网络地址 192.1.1.0/24 包含的 IP 地址范围，其中 192.1.1.0 是网络地址，255.255.255.0 是子网掩码。命令 network 指定的 IP 地址范围只能是某个网络地址包含的 IP 地址范围。

exit 命令的作用是从 DHCP 配置模式返回到全局模式。

(4) 完成 Web 服务器网络信息配置过程，Web 服务器网络信息配置界面如图 6 所示。

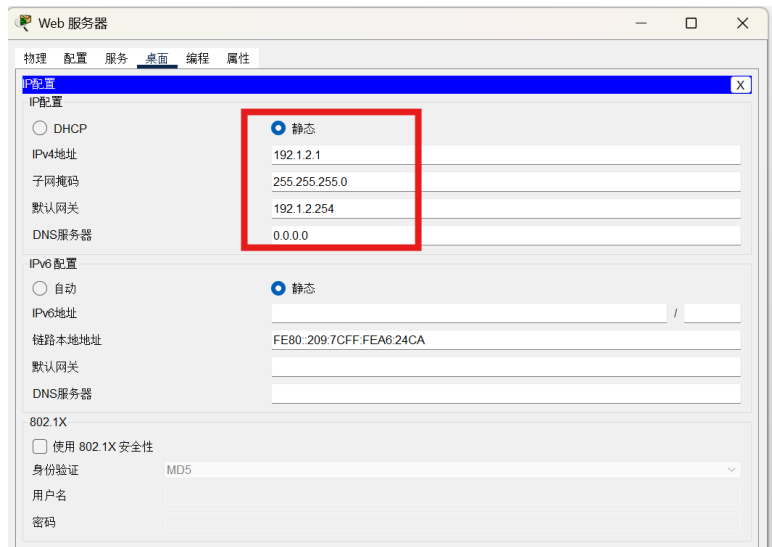


图 6 Web 服务器网络信息配置界面

(5) 由于路由器 Router 为由 Switch1 构成的以太网定义了名为 lan1 的作用域, 因此, 连接在 Switch1 上的终端可以通过 DHCP 自动获取网络信息。完成 PC0 “Desktop (桌面)” → “IP Configuration (IP 配置)” 操作过程, 弹出如图 7 所示的 PC0 网络信息配置界面, 选择 DHCP 选项, PC0 自动获取如图 7 所示的网络信息。用同样的方式, 使 PC1、PC2 和 PC3 自动获取网络信息。

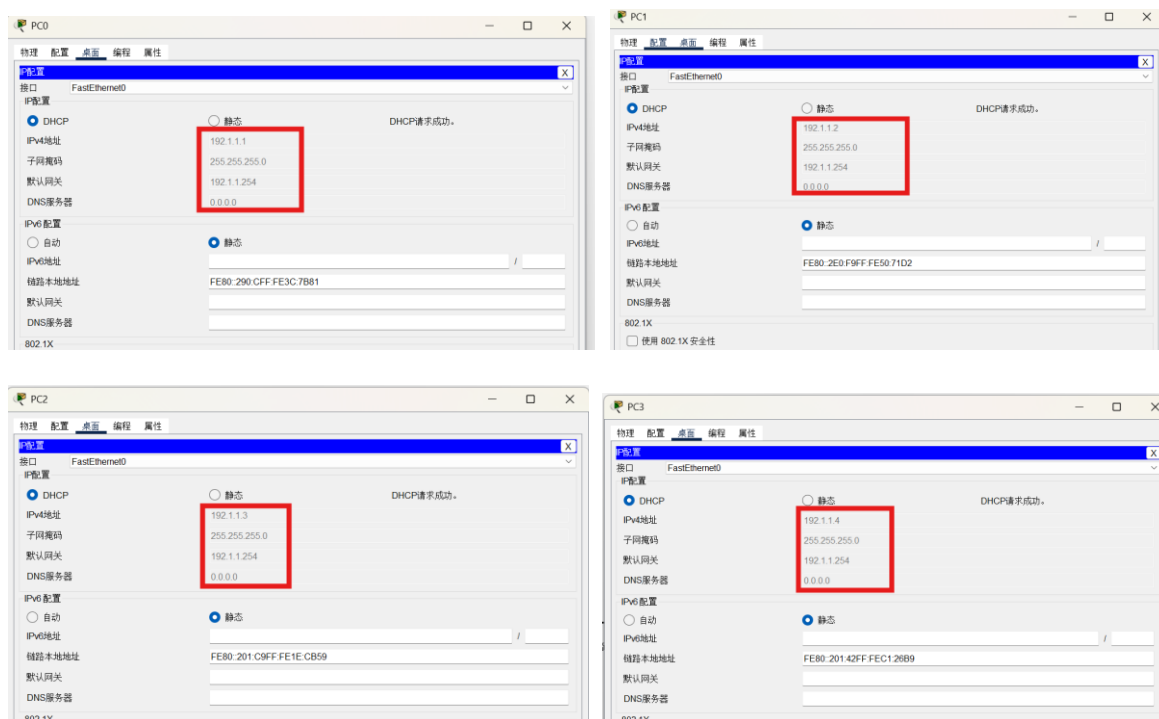


图 7 PC0/PC1/PC2/PC3 自动获取网络信息界面

(6) 切换到模拟操作模式, 通过复杂报文工具在 PC0 上生成如图 8 所示的 ICMP ECHO 请求报文, 该 ICMP ECHO 请求报文封装成源 IP 地址是 Web 服务器的 IP 地址 192.1.2.1、目的 IP 地址是全 1 的广播地址的 IP 分组。该 IP 分组在由 Switch1 构成的以太网上广播, 到达所有其他终端和路由器 Router, 如图 9 所示。

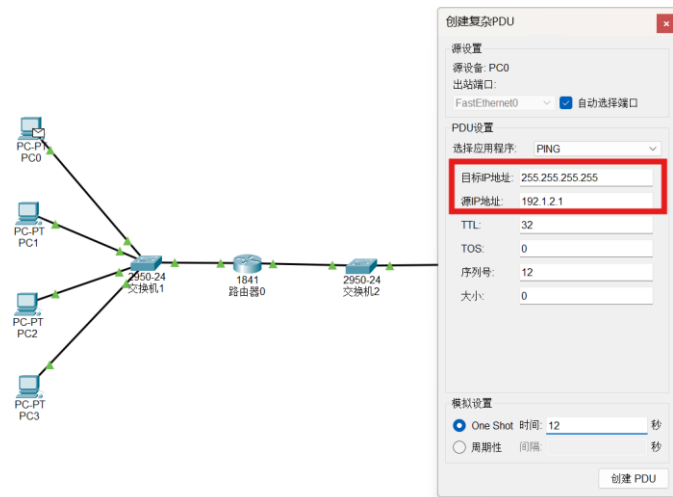


图 8 复杂报文工具在 PC0 上生成的 ICMP ECHO 请求报文

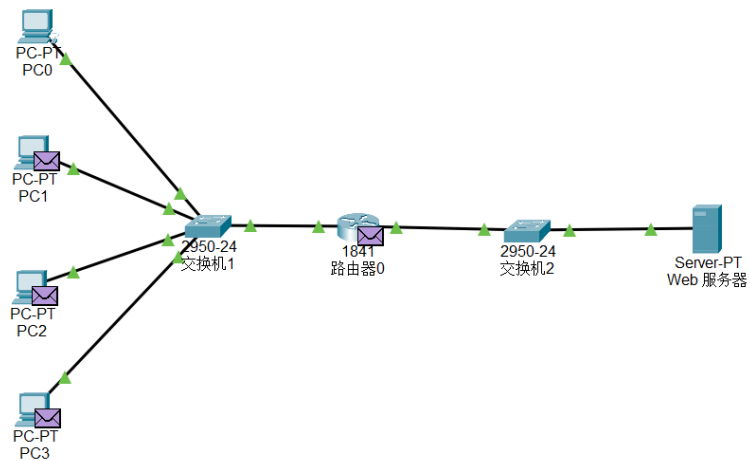


图 9 ICMP ECHO 请求报文广播过程

(7) 由于封装 ICMP ECHO 请求报文的 IP 分组的源 IP 地址是 Web 服务器的 IP 地址，所有接收到 ICMP ECHO 请求报文的终端，向 Web 服务器发送 ICMP ECHO 响应报文，导致 Web 服务器接收到三个 ICMP ECHO 响应报文，如图 10 所示。

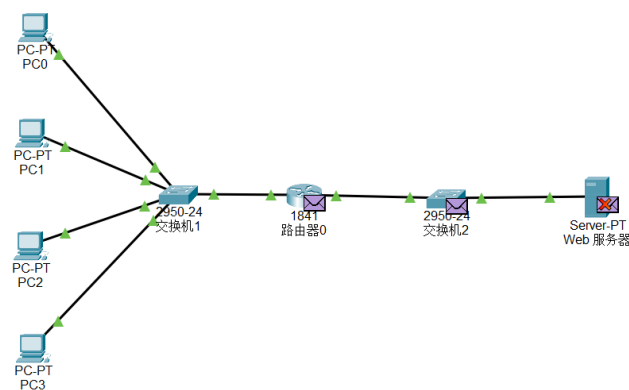


图 10 所有终端向 Web 服务器发送 ICMP ECHO 响应报文

本次实验所用到的重要命令如下：

命令格式	功能和参数说明
enable	没有参数，从用户模式进入特权模式
configure terminal	没有参数，从特权模式进入全局模式
exit	没有参数，退出当前模式，返回到上一层模式
interface port-id	进入由参数 port-id 指定的路由器接口的接口配置模式
ip address ip-address subnet-mask	为路由器接口配置 IP 地址和子网掩码。参数 ip-address 是用户配置的 IP 地址，参数 subnet-mask 是用户配置的子网掩码
no shutdown	没有参数，开启某个路由器接口

表 1 Smurf 攻击实验重要命令

五、实验分析总结及心得

这次 Smurf 攻击实验里，我先通过路由器 CLI 配 DHCP 时，一开始把 default-router 写成了 192.1.2.254，结果 LAN1 里的终端没拿到正确网关，DHCP 一直失败，查了命令列表才发现该填路由器 LAN1 接口的 192.1.1.254，后面实验成功了，Web 服务器收到了 3 个响应报文，验证了 Smurf 利用广播地址放大流量、伪造源 IP 实现反射攻击的原理。通过这次实验，我不光摸清了 Smurf 攻击“伪造源 IP + 广播放大”的逻辑，也掌握了路由器 DHCP 作用域的配置方法，更体会到网络攻防里“细节”有多重要——不管是命令参数填错，还是接口状态没开，都会让实验卡壳，而攻击本身往往就是利用了这些配置疏漏，以后不管配设备还是防攻击，都得把协议逻辑和实操细节扣清楚。